

Findings

Critical

Finding 33: GHSA-jf85-cpcp-j695 in lodash:2.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	2.44% / 84.92%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
lodash	2.4.2

File Path
/juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Prototype Pollution in lodash

Related Vulnerability Description: Versions of lodash lower than 4.17.12 are vulnerable to Prototype Pollution. The function defaultsDeep could be tricked into adding or modifying properties of Object.prototype using a constructor payload.

Matcher: javascript-matcher

Package URL: pkg:npm/lodash@2.4.2

Mitigation

Upgrade to version: 4.17.12

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-jf85-cpcp-j695>

Vulnerability URLs:

- <https://github.com/lodash/lodash/pull/4336>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-10744>
- <https://snyk.io/vuln/SNYK-JS-LODASH-450202>
- <https://access.redhat.com/errata/RHSA-2019:3024>
- https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS
- <https://www.oracle.com/security-alerts/cpujan2021.html>

- <https://www.oracle.com/security-alerts/cpuoct2020.html>
- https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS
- <https://security.netapp.com/advisory/ntap-20191004-0005>
- <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2019-10744.yml>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2019-10744>

Related Vulnerability URLs:

- <https://access.redhat.com/errata/RHSA-2019:3024>
- <https://security.netapp.com/advisory/ntap-20191004-0005/>
- <https://snyk.io/vuln/SNYK-JS-LODASH-450202>
- https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS
- <https://www.oracle.com/security-alerts/cpujan2021.html>
- <https://www.oracle.com/security-alerts/cpuoct2020.html>

Finding 112: CVE-2025-55130 in node:22.18.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	0.01% / 1.58%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
node	22.18.0

File Path
/nodejs/bin/node

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: nvd:cpe

Vulnerability Description: A flaw in Node.js's Permissions model allows attackers to bypass --allow-fs-read and --allow-fs-write restrictions using crafted relative symlink paths. By chaining directories and symlinks, a script granted access only to the current directory can escape the allowed path and read sensitive files. This breaks the expected isolation guarantees and enables arbitrary file read/write, leading to potential system compromise.

This vulnerability affects users of the permission model on Node.js v20, v22, v24, and v25.

Matcher: stock-matcher

Package URL: pkg:generic/node@22.18.0

Mitigation

Upgrade to version:

- 20.20.0
- 22.22.0
- 24.13.0
- 25.3.0

References

Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-55130>

Vulnerability URL: <https://nodejs.org/en/blog/vulnerability/december-2025-security-releases>

Finding 27: GHSA-whpj-8f3w-67p5 in vm2:3.9.17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	69.88% / 98.63%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
vm2	3.9.17

File Path
/juice-shop/node_modules/vm2/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: vm2 Sandbox Escape vulnerability

Related Vulnerability Description: vm2 is a sandbox that can run untrusted code with Node's built-in modules. A sandbox escape vulnerability exists in vm2 for versions up to and including 3.9.17. It abuses an unexpected creation of a host object based on the specification of Proxy. As a result a threat actor can bypass the sandbox protections to gain remote code execution rights on the host running the sandbox. This vulnerability was patched in the release of version 3.9.18 of vm2. Users are advised to upgrade. There are no known workarounds for this vulnerability.

Matcher: javascript-matcher

Package URL: pkg:npm/vm2@3.9.17

Mitigation

Upgrade to version: 3.9.18

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-whpj-8f3w-67p5>

Vulnerability URLs:

- <https://github.com/patriksimek/vm2/security/advisories/GHSA-whpj-8f3w-67p5>
- <https://github.com/patriksimek/vm2/commit/d88105f99752305c5b8a77b63ddee3ec86912daf>
- <https://github.com/patriksimek/vm2/releases/tag/3.9.18>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-32314>
- <https://gist.github.com/arkark/e9f5cf5782dec8321095be3e52acf5ac>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2023-32314>

Related Vulnerability URLs:

- <https://gist.github.com/arkark/e9f5cf5782dec8321095be3e52acf5ac>
- <https://github.com/patriksimek/vm2/commit/d88105f99752305c5b8a77b63ddee3ec86912daf>
- <https://github.com/patriksimek/vm2/releases/tag/3.9.18>
- <https://github.com/patriksimek/vm2/security/advisories/GHSA-whpj-8f3w-67p5>

Finding 28: GHSA-g644-9gfx-q4q4 in vm2:3.9.17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	39.23% / 97.19%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
vm2	3.9.17

File Path
/juice-shop/node_modules/vm2/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: vm2 Sandbox Escape vulnerability

Related Vulnerability Description: vm2 is an open source vm/sandbox for Node.js. In vm2 for versions up to and including 3.9.19, Node.js custom inspect function allows attackers to escape the sandbox and run arbitrary code. This may result in Remote Code Execution, assuming the attacker has arbitrary code execution primitive inside the context of vm2 sandbox. There are no patches and no known workarounds. Users are advised to find an alternative software.

Matcher: javascript-matcher

Package URL: pkg:npm/vm2@3.9.17

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-g644-9gfx-q4q4>

Vulnerability URLs:

- <https://github.com/patriksimek/vm2/security/advisories/GHSA-g644-9gfx-q4q4>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-37903>
- <https://security.netapp.com/advisory/ntap-20230831-0007>
- <https://security.netapp.com/advisory/ntap-20241108-0002>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2023-37903>

Related Vulnerability URLs:

- <https://github.com/patriksimek/vm2/security/advisories/GHSA-g644-9gfx-q4q4>
- <https://security.netapp.com/advisory/ntap-20230831-0007/>
- <https://security.netapp.com/advisory/ntap-20241108-0002/>

Finding 37: GHSA-xwcq-pm8m-c4vf in crypto-js:3.3.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	0.82% / 74.12%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
crypto-js	3.3.0

File Path
/juice-shop/node_modules/crypto-js/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: crypto-js PBKDF2 1,000 times weaker than specified in 1993 and 1.3M times weaker than current standard

Related Vulnerability Description: crypto-js is a JavaScript library of crypto standards. Prior to version 4.2.0, crypto-js PBKDF2 is 1,000 times weaker than originally specified in 1993, and at least 1,300,000 times weaker than current industry standard. This is because it both defaults to SHA1, a cryptographic hash algorithm considered insecure since at least 2005, and defaults to one single iteration, a 'strength' or 'difficulty' value specified at 1,000 when specified in 1993. PBKDF2 relies on iteration count as a countermeasure to preimage and collision attacks. If used to protect passwords, the impact is high. If used to generate signatures, the impact is high. Version 4.2.0 contains a patch for this issue. As a workaround, configure crypto-js to use SHA256 with at least 250,000 iterations.

Matcher: javascript-matcher

Package URL: pkg:npm/crypto-js@3.3.0

Mitigation

Upgrade to version: 4.2.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-xwcq-pm8m-c4vf>

Vulnerability URLs:

- <https://github.com/brix/crypto-js/security/advisories/GHSA-xwcq-pm8m-c4vf>
- <https://github.com/brix/crypto-js/commit/421dd538b2d34e7c24a5b72cc64dc2b9167db40a>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-46233>
- <https://lists.debian.org/debian-lts-announce/2023/11/msg00025.html>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2023-46233>

Related Vulnerability URLs:

- <https://github.com/brix/crypto-js/commit/421dd538b2d34e7c24a5b72cc64dc2b9167db40a>
- <https://github.com/brix/crypto-js/security/advisories/GHSA-xwcq-pm8m-c4vf>
- <https://lists.debian.org/debian-lts-announce/2023/11/msg00025.html>

Finding 29: GHSA-c7hr-j4mj-j2w6 in jsonwebtoken:0.1.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	32.47% / 96.75%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.1.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Verification Bypass in jsonwebtoken

Related Vulnerability Description: In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS *family*).

Matcher: javascript-matcher

Package URL.* pkg:npm/jsonwebtoken@0.1.0

Mitigation

Upgrade to version: 4.2.2

References

Vulnerability Datasource: https://github.com/advisories/GHSA-c7hr-j4mj-j2w6

Vulnerability URLs:

- https://nvd.nist.gov/vuln/detail/CVE-2015-9235
- https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687
- https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/
- https://www.npmjs.com/advisories/17
- https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Related Vulnerability Datasource: https://nvd.nist.gov/vuln/detail/CVE-2015-9235

Related Vulnerability URLs:

- https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/
- https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687
- https://nodesecurity.io/advisories/17
- https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Finding 39: CVE-2025-15467 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	0.70% / 71.75%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: Parsing CMS AuthEnvelopedData or EnvelopedData message with maliciously crafted AEAD parameters can trigger a stack buffer overflow. Impact summary: A stack buffer overflow may lead to a crash, causing Denial of Service, or potentially remote code execution. When parsing CMS (Auth)EnvelopedData structures that use AEAD ciphers such as AES-GCM, the IV (Initialization Vector) encoded in the ASN.1 parameters is copied into a fixed-size stack buffer without verifying that its length fits the destination. An attacker can supply a crafted CMS message with an oversized IV, causing a stack-based out-of-bounds write before any authentication or tag verification occurs. Applications and services that parse untrusted CMS or PKCS#7 content using AEAD ciphers (e.g., S/MIME (Auth)EnvelopedData with AES-GCM) are vulnerable. Because the overflow occurs prior to authentication, no valid key material is required to trigger it. While exploitability to remote code execution depends on platform and toolchain mitigations, the stack-based write primitive represents a severe risk. The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the CMS implementation is outside the OpenSSL FIPS module boundary. OpenSSL 3.6, 3.5, 3.4, 3.3 and 3.0 are vulnerable to this issue. OpenSSL 1.1.1 and 1.0.2 are not affected by this issue.

Related Vulnerability Description: Issue summary: Parsing CMS AuthEnvelopedData or EnvelopedData message with maliciously crafted AEAD parameters can trigger a stack buffer overflow.

Impact summary: A stack buffer overflow may lead to a crash, causing Denial of Service, or potentially remote code execution.

When parsing CMS (Auth)EnvelopedData structures that use AEAD ciphers such as AES-GCM, the IV (Initialization Vector) encoded in the ASN.1 parameters is copied into a fixed-size stack buffer without verifying that its length fits the destination. An attacker can supply a crafted CMS message with an oversized IV, causing a stack-based out-of-bounds write before any authentication or tag verification occurs.

Applications and services that parse untrusted CMS or PKCS#7 content using AEAD ciphers (e.g., S/MIME (Auth)EnvelopedData with AES-GCM) are vulnerable. Because the overflow occurs prior to authentication, no valid key material is required to trigger it. While exploitability to remote code execution depends on platform and toolchain mitigations, the stack-based write primitive represents a severe risk.

The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the CMS implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3 and 3.0 are vulnerable to this issue.

OpenSSL 1.1.1 and 1.0.2 are not affected by this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-15467>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-15467>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/2c8f0e5fa9b6ee5508a0349e4572ddb74db5a703>
- <https://github.com/openssl/openssl/commit/5f26d4202f5b89664c5c3f3c62086276026ba9a9>
- <https://github.com/openssl/openssl/commit/6ced0fe6b10faa560e410e3ee8d6c82f06c65ea3>
- <https://github.com/openssl/openssl/commit/ce39170276daec87f55c39dad1f629b56344429e>
- <https://github.com/openssl/openssl/commit/d0071a0799f20cc8101730145349ed4487c268dc>
- <https://openssl-library.org/news/secadv/20260127.txt>
- <http://www.openwall.com/lists/oss-security/2026/01/27/10>
- <http://www.openwall.com/lists/oss-security/2026/02/25/6>

Finding 30: GHSA-c7hr-j4mj-j2w6 in jsonwebtoken:0.4.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	32.47% / 96.75%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.4.0

File Path
/juice-shop/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Verification Bypass in jsonwebtoken

Related Vulnerability Description: In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS *family*).

Matcher: javascript-matcher

*Package URL.** pkg:npm/jsonwebtoken@0.4.0

Mitigation

Upgrade to version: 4.2.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>
- <https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>
- <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- <https://www.npmjs.com/advisories/17>
- <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>

Related Vulnerability URLs:

- <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- <https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>
- <https://nodesecurity.io/advisories/17>
- <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Finding 95: GHSA-99p7-6v5w-7xg8 in vm2:3.9.17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	0.03% / 8.37%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
vm2	3.9.17

File Path
/juice-shop/node_modules/vm2/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: vm2 has a Sandbox Escape

Related Vulnerability Description: vm2 is an open source vm/sandbox for Node.js. In vm2 prior to version 3.10.2, Promise.prototype.then Promise.prototype.catch callback sanitization can be bypassed. This allows attackers to escape the sandbox and run arbitrary code. In lib/setup-sandbox.js, the callback function of localPromise.prototype.then is sanitized, but globalPromise.prototype.then is not sanitized. The return value of async functions is globalPromise object. Version 3.10.2 fixes the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/vm2@3.9.17

Mitigation

Upgrade to version: 3.10.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-99p7-6v5w-7xg8>

Vulnerability URLs:

- <https://github.com/patriksimek/vm2/security/advisories/GHSA-99p7-6v5w-7xg8>
- <https://github.com/patriksimek/vm2/commit/4b009c2d4b1131c01810c1205e641d614c322a29>
- <https://github.com/patriksimek/vm2/releases/tag/v3.10.2>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-22709>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-22709>

Related Vulnerability URLs:

- <https://github.com/patriksimek/vm2/commit/4b009c2d4b1131c01810c1205e641d614c322a29>
- <https://github.com/patriksimek/vm2/releases/tag/v3.10.2>
- <https://github.com/patriksimek/vm2/security/advisories/GHSA-99p7-6v5w-7xg8>

Finding 31: GHSA-cchq-frgv-rjh5 in vm2:3.9.17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	5.00% / 89.50%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
vm2	3.9.17

File Path
/juice-shop/node_modules/vm2/package.json

CVSS v3

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: vm2 Sandbox Escape vulnerability

Related Vulnerability Description: vm2 is an advanced vm/sandbox for Node.js. The library contains critical security issues and should not be used for production. The maintenance of the project has been discontinued. In vm2 for versions up to 3.9.19, Promise handler sanitization can be bypassed with the @@species accessor property allowing attackers to escape the sandbox and run arbitrary code, potentially allowing remote code execution inside the context of vm2 sandbox. Version 3.10.0 contains a patch for the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/vm2@3.9.17

Mitigation

Upgrade to version: 3.10.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-cchq-frgv-rjh5>

Vulnerability URLs:

- <https://github.com/patriksimek/vm2/security/advisories/GHSA-cchq-frgv-rjh5>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-37466>
- <https://gist.github.com/leesh3288/f693061e6523c97274ad5298eb2c74e9>
- <https://security.netapp.com/advisory/ntap-20230831-0007>
- <https://security.netapp.com/advisory/ntap-20241108-0002>
- <https://github.com/patriksimek/vm2/commit/d9a1fde8ec5a5a9c9e5a69bf91d703950859d744>
- <https://github.com/patriksimek/vm2/releases/tag/v3.10.0>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2023-37466>

Related Vulnerability URLs:

- <https://github.com/patriksimek/vm2/commit/d9a1fde8ec5a5a9c9e5a69bf91d703950859d744>
- <https://github.com/patriksimek/vm2/releases/tag/v3.10.0>
- <https://github.com/patriksimek/vm2/security/advisories/GHSA-cchq-frgv-rjh5>
- <https://security.netapp.com/advisory/ntap-20241108-0002/>

Finding 143: GHSA-5mrr-rgp6-x4gr in marsdb:0.6.11

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Critical	N.A. / N.A.	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
marsdb	0.6.11

File Path
/juice-shop/node_modules/marsdb/package.json

Description

Vulnerability Namespace: github:language:javascript**Vulnerability Description:** Command Injection in marsdb**Matcher:** javascript-matcher**Package URL:** pkg:npm/marsdb@0.6.11

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-5mrr-rgp6-x4gr>**Vulnerability URLs:**- <https://github.com/bkimminich/juice-shop/issues/1173>- <https://www.npmjs.com/advisories/1122>

High

Finding 85: GHSA-7r86-cg39-jmmj in minimatch:9.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 14.46%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	9.0.5

File Path
/juice-shop/node_modules/glob/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript**Vulnerability Description:** minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is $O(C(n, k))$ -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@9.0.5

Mitigation

Upgrade to version: 9.0.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-7r86-cg39-jmmj>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

Finding 94: GHSA-5j98-mcp5-4vw2 in glob:10.4.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.04% / 11.34%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
glob	10.4.5

File Path
/juice-shop/node_modules/glob/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: glob CLI: Command injection via -c/--cmd executes matches with shell:true

Related Vulnerability Description: Glob matches files using patterns the shell uses. Starting in version 10.2.0 and prior to versions 10.5.0 and 11.1.0, the glob CLI contains a command injection vulnerability in its -c/--cmd option that allows arbitrary command execution when processing files with malicious names. When glob -c <command> <patterns> are used, matched filenames are passed to a shell with shell: true, enabling shell metacharacters in filenames to trigger command injection and achieve arbitrary code execution under the user or CI account privileges. This issue has been patched in versions 10.5.0 and 11.1.0.

Matcher: javascript-matcher

Package URL: pkg:npm/glob@10.4.5

Mitigation

Upgrade to version: 10.5.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-5j98-mcp5-4vw2>

Vulnerability URLs:

- <https://github.com/isaacs/node-glob/security/advisories/GHSA-5j98-mcp5-4vw2>
- <https://github.com/isaacs/node-glob/commit/47473c046b91c67269df7a66eab782a6c2716146>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-64756>
- <https://github.com/isaacs/node-glob/commit/1e4e297342a09f2aa0ced87fcd4a70ddc325d75f>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-64756>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-glob/commit/1e4e297342a09f2aa0ced87fcd4a70ddc325d75f>
- <https://github.com/isaacs/node-glob/commit/47473c046b91c67269df7a66eab782a6c2716146>
- <https://github.com/isaacs/node-glob/security/advisories/GHSA-5j98-mcp5-4vw2>

Finding 87: GHSA-23c5-xmqv-rm74 in minimatch:3.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.04% / 11.97%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.0.5

File Path
/juice-shop/node_modules/replace/node_modules/minimatch/package.json

CVSS v3

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch ReDoS: nested () extglobs generate catastrophically backtracking regular expressions

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested *() extglobs produce regexps with nested unbounded quantifiers (e.g. (?:?(a|b)*)*), which exhibit catastrophic backtracking in V8. With a 12-byte pattern *((*(a|b))) and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects +() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Matcher: javascript-matcher

Package URL.* pkg:npm/minimatch@3.0.5

Mitigation

Upgrade to version: 3.1.4

References

Vulnerability Datasource: https://github.com/advisories/GHSA-23c5-xmqv-rm74

Vulnerability URLs:

- https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74
- https://nvd.nist.gov/vuln/detail/CVE-2026-27904
- https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce

Related Vulnerability Datasource: https://nvd.nist.gov/vuln/detail/CVE-2026-27904

Related Vulnerability URL: https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74

Finding 88: GHSA-23c5-xmqv-rm74 in minimatch:3.0.8

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.04% / 11.97%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.0.8

File Path
/juice-shop/node_modules/grunt/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch ReDoS: nested () extglobs generate catastrophically backtracking regular expressions

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested *() extglobs produce regexps with nested unbounded quantifiers (e.g. (?:a|b)*), which exhibit catastrophic backtracking in V8. With a 12-byte pattern *((*(a|b))) and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects +() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Matcher: javascript-matcher

Package URL.* pkg:npm/minimatch@3.0.8

Mitigation

Upgrade to version: 3.1.4

References

Vulnerability Datasource: https://github.com/advisories/GHSA-23c5-xmqv-rm74

Vulnerability URLs:

- https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74
- https://nvd.nist.gov/vuln/detail/CVE-2026-27904
- https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce

Related Vulnerability Datasource: https://nvd.nist.gov/vuln/detail/CVE-2026-27904

Related Vulnerability URL: https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74

Finding 89: GHSA-23c5-xmqv-rm74 in minimatch:3.1.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.04% / 11.97%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.1.2

File Path
/juice-shop/node_modules/archiver/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch ReDoS: nested `()` extglobs generate catastrophically backtracking regular expressions

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested `*` extglobs produce regexps with nested unbounded quantifiers (e.g. `?(?:a|b)*`), which exhibit catastrophic backtracking in V8. With a 12-byte pattern `*(*(a|b))` and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects `+` extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@3.1.2

Mitigation

Upgrade to version: 3.1.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-23c5-xmqv-rm74>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>
- <https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>

Finding 90: GHSA-23c5-xmqv-rm74 in minimatch:5.1.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.04% / 11.97%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	5.1.6

File Path
/juice-shop/node_modules/filehound/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch ReDoS: nested `()` extglobs generate catastrophically backtracking regular expressions

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested `*`() extglobs produce regexps with nested unbounded quantifiers (e.g. `?(?:a|b)*`), which exhibit catastrophic backtracking in V8. With a 12-byte pattern `*(*(*a|b))` and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects `+`() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Matcher: javascript-matcher

Package URL.* pkg:npm/minimatch@5.1.6

Mitigation

Upgrade to version: 5.1.8

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-23c5-xmqv-rm74>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>
- <https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>

Finding 91: GHSA-23c5-xmqv-rm74 in minimatch:9.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.04% / 11.97%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	9.0.5

File Path
/juice-shop/node_modules/glob/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch ReDoS: nested `()` extglobs generate catastrophically backtracking regular expressions

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested `*`() extglobs produce regexps with nested unbounded quantifiers (e.g. `?(?:a|b)*`), which exhibit catastrophic backtracking in V8. With a 12-byte pattern `*(*(*a|b))` and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects `+`() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Matcher: javascript-matcher

Package URL.* pkg:npm/minimatch@9.0.5

Mitigation

Upgrade to version: 9.0.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-23c5-xmqv-rm74>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>
- <https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>

Finding 116: GHSA-34x7-hfp2-rc4v in tar:6.2.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.77%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	6.2.1

File Path
/juice-shop/node_modules/sqlite3/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal

Related Vulnerability Description: node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows

Matcher: javascript-matcher

Package URL: pkg:npm/tar@6.2.1

Mitigation

Upgrade to version: 7.5.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-34x7-hfp2-rc4v>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>
- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>

Finding 115: GHSA-34x7-hfp2-rc4v in tar:4.4.19

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.77%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	4.4.19

File Path
/juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal

Related Vulnerability Description: node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside

the extraction directory. Version 7.5.7 contains a fix for the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@4.4.19

Mitigation

Upgrade to version: 7.5.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-34x7-hfp2-rc4v>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>
- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>

Finding 110: CVE-2025-4802 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.02% / 3.36%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Untrusted LD_LIBRARY_PATH environment variable vulnerability in the GNU C Library version 2.27 to 2.38 allows attacker controlled loading of dynamically shared library in statically compiled setuid binaries that call dlopen (including internal dlopen calls after setlocale or calls to NSS functions such as getaddrinfo).

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

Mitigation

Upgrade to version: 2.36-9+deb12u11

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-4802>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-4802>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=32976
- <https://sourceware.org/cgit/glibc/commit/?id=1e18586c5820e329f741d5c710275e165581380e>
- <http://www.openwall.com/lists/oss-security/2025/05/16/7>
- <http://www.openwall.com/lists/oss-security/2025/05/17/2>
- <https://lists.debian.org/debian-lts-announce/2025/05/msg00033.html>

Finding 107: CVE-2026-0915 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.02% / 4.58%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Calling getnetbyaddr or getnetbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend for networks and queries for a zero-valued network in the GNU C Library version 2.0 to version 2.42 can leak stack contents to the configured DNS resolver.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2026-0915>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-0915>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=33802
- <http://www.openwall.com/lists/oss-security/2026/01/16/6>

Finding 104: CVE-2025-9230 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.02% / 5.86%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: An application trying to decrypt CMS messages encrypted using password based encryption can trigger an out-of-bounds read and write. Impact summary: This out-of-bounds read may trigger a crash which leads to Denial of Service for an application. The out-of-bounds write can cause a memory corruption which can have various consequences including a Denial of Service or Execution of attacker-supplied code. Although the consequences of a successful exploit of this vulnerability could be severe, the probability that the attacker would be able to perform it is low. Besides, password based (PWRI) encryption support in CMS messages is very rarely used. For that reason the issue was assessed as Moderate severity according to our Security Policy. The FIPS modules in 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this issue, as the CMS implementation is outside the OpenSSL FIPS module boundary.

Related Vulnerability Description: Issue summary: An application trying to decrypt CMS messages encrypted using password based encryption can trigger an out-of-bounds read and write.

Impact summary: This out-of-bounds read may trigger a crash which leads to Denial of Service for an application. The out-of-bounds write can cause a memory corruption which can have various consequences including a Denial of Service or Execution of attacker-supplied code.

Although the consequences of a successful exploit of this vulnerability could be severe, the probability that the attacker would be able to

perform it is low. Besides, password based (PWRI) encryption support in CMS messages is very rarely used. For that reason the issue was assessed as Moderate severity according to our Security Policy.

The FIPS modules in 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this issue, as the CMS implementation is outside the OpenSSL FIPS module boundary.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.17-1~deb12u3

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-9230>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-9230>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/5965ea5dd6960f36d8b7f74f8eac67a8eb8f2b45>
- <https://github.com/openssl/openssl/commit/9e91358f365dee6c446dcdcdb01c04d2743fd280>
- <https://github.com/openssl/openssl/commit/a79c4ce559c6a3a8fd4109e9f33c1185d5bf2def>
- <https://github.com/openssl/openssl/commit/b5282d677551afda7d20e9c00e09561b547b2dfd>
- <https://github.com/openssl/openssl/commit/bae259a211ada6315dc50900686daaaaaa55f482>
- <https://github.com/openssl/openssl/extended-releases/commit/c2b96348bfa662f25f4fabf81958ae822063dae3>
- <https://github.com/openssl/openssl/extended-releases/commit/dfbaf161d8dafc1132dd88cd48ad990ed9b4c8ba>
- <https://openssl-library.org/news/secadv/20250930.txt>
- <http://www.openwall.com/lists/oss-security/2025/09/30/5>
- <https://lists.debian.org/debian-lts-announce/2025/10/msg00001.html>

Finding 103: CVE-2025-59466 in node:22.18.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.03% / 6.82%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
node	22.18.0

File Path
/nodejs/bin/node

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: nvd:cpe

Vulnerability Description: We have identified a bug in Node.js error handling where "Maximum call stack size exceeded" errors become uncatchable when `async_hooks.createHook()` is enabled. Instead of reaching `process.on('uncaughtException')`, the process terminates, making the crash unrecoverable. Applications that rely on `AsyncLocalStorage` (v22, v20) or `async_hooks.createHook()` (v24, v22, v20) become vulnerable to denial-of-service crashes triggered by deep recursion under specific conditions.

Matcher: stock-matcher

Package URL: pkg:generic/node@22.18.0

Mitigation

Upgrade to version:

- 20.20.0
- 22.22.0
- 24.13.0
- 25.3.0

References

Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-59466>

Vulnerability URL: <https://nodejs.org/en/blog/vulnerability/december-2025-security-releases>

Finding 26: GHSA-2p57-rm9w-gvfp in ip:2.0.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	86.50% / 99.40%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
ip	2.0.1

File Path
/juice-shop/node_modules/ip/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: ip SSRF improper categorization in isPublic

Related Vulnerability Description: The ip package through 2.0.1 for Node.js might allow SSRF because some IP addresses (such as 127.1, 01200034567, 012.1.2.3, 000:0:0000:01, and ::fFfF:127.0.0.1) are improperly categorized as globally routable via isPublic. NOTE: this issue exists because of an incomplete fix for CVE-2023-42282.

Matcher: javascript-matcher

Package URL: pkg:npm/ip@2.0.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-2p57-rm9w-gvfp>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2024-29415>
- <https://github.com/indutny/node-ip/issues/150>
- <https://github.com/indutny/node-ip/pull/143>
- <https://github.com/indutny/node-ip/pull/144>
- <https://security.netapp.com/advisory/ntap-20250117-0010>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-29415>

Related Vulnerability URLs:

- <https://github.com/indutny/node-ip/issues/150>
- <https://github.com/indutny/node-ip/pull/143>
- <https://github.com/indutny/node-ip/pull/144>
- <https://security.netapp.com/advisory/ntap-20250117-0010/>

Finding 34: GHSA-p6mc-m468-83gw in lodash.set:4.3.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	2.55% / 85.22%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
lodash.set	4.3.2

File Path
/juice-shop/node_modules/lodash.set/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript**Vulnerability Description:** Prototype Pollution in lodash**Related Vulnerability Description:** Prototype pollution attack when using _.zipObjectDeep in lodash before 4.17.20.**Matcher:** javascript-matcher**Package URL:** pkg:npm/lodash.set@4.3.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-p6mc-m468-83gw>**Vulnerability URLs:**

- <https://github.com/lodash/lodash/issues/4744>
- <https://github.com/lodash/lodash/commit/c84fe82760fb2d3e03a63379b297a1cc1a2fce12>
- <https://nvd.nist.gov/vuln/detail/CVE-2020-8203>
- <https://hackerone.com/reports/712065>
- <https://github.com/lodash/lodash/issues/4874>
- <https://github.com/github/advisory-database/pull/2884>
- <https://hackerone.com/reports/864701>
- <https://github.com/lodash/lodash/wiki/Changelog#v41719>
- <https://web.archive.org/web/20210914001339/https://github.com/lodash/lodash/issues/4744>
- <https://security.netapp.com/advisory/ntap-20200724-0006>
- <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2020-8203.yml>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2020-8203>

Related Vulnerability URLs:

- <https://github.com/lodash/lodash/issues/4874>
- <https://hackerone.com/reports/712065>
- <https://security.netapp.com/advisory/ntap-20200724-0006/>
- <https://www.oracle.com//security-alerts/cpujul2021.html>
- <https://www.oracle.com/security-alerts/cpuApr2021.html>
- <https://www.oracle.com/security-alerts/cpuapr2022.html>
- <https://www.oracle.com/security-alerts/cpujan2022.html>
- <https://www.oracle.com/security-alerts/cpuoct2021.html>

Finding 35: GHSA-8hjf-j24r-96c4 in moment:2.0.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	1.67% / 81.88%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
moment	2.0.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Path Traversal: 'dir/../../filename' in moment.locale

Related Vulnerability Description: Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

Matcher: javascript-matcher

Package URL: pkg:npm/moment@2.0.0

Mitigation

Upgrade to version: 2.29.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8hfj-j24r-96c4>

Vulnerability URLs:

- <https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-24785>
- <https://github.com/moment/moment/commit/4211bfc8f15746be4019bba557e29a7ba83d54c5>
- <https://www.tenable.com/security/tns-2022-09>
- <https://lists.debian.org/debian-lts-announce/2023/01/msg00035.html>
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTk2T7SPKDS4JEL45FANLNC2Q>
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5>
- <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/6QIO6YNLTk2T7SPKDS4JEL45FANLNC2Q>
- <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5>
- <https://security.netapp.com/advisory/ntap-20220513-0006>
- <https://security.netapp.com/advisory/ntap-20241108-0002>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-24785>

Related Vulnerability URLs:

- <https://github.com/moment/moment/commit/4211bfc8f15746be4019bba557e29a7ba83d54c5>
- <https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4>
- <https://lists.debian.org/debian-lts-announce/2023/01/msg00035.html>
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTk2T7SPKDS4JEL45FANLNC2Q/>
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5/>
- <https://security.netapp.com/advisory/ntap-20220513-0006/>
- <https://www.tenable.com/security/tns-2022-09>
- <https://security.netapp.com/advisory/ntap-20241108-0002/>

Finding 134: GHSA-8qq5-rm4j-mr97 in tar:7.4.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.28%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	7.4.3

File Path
/juice-shop/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization

Related Vulnerability Description: node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@7.4.3

Mitigation

Upgrade to version: 7.5.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8qq5-rm4j-mr97>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>
- <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>

Finding 133: GHSA-8qq5-rm4j-mr97 in tar:6.2.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.28%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	6.2.1

File Path
/juice-shop/node_modules/sqlite3/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization

Related Vulnerability Description: node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@6.2.1

Mitigation

Upgrade to version: 7.5.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8qq5-rm4j-mr97>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>
- <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>

Finding 40: GHSA-35jh-r3h4-6jhm in lodash:2.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.74% / 72.62%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
lodash	2.4.2

File Path
/juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Command Injection in lodash

Related Vulnerability Description: Lodash versions prior to 4.17.21 are vulnerable to Command Injection via the template function.

Matcher: javascript-matcher

Package URL: pkg:npm/lodash@2.4.2

Mitigation

Upgrade to version: 4.17.21

References

- Vulnerability Datasource:** <https://github.com/advisories/GHSA-35jh-r3h4-6jhm>
- Vulnerability URLs:**
- <https://nvd.nist.gov/vuln/detail/CVE-2021-23337>
 - <https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b5a91dde28ba4b1c>
 - <https://snyk.io/vuln/SNYK-JS-LODASH-1040724>
 - <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js#L14851>
 - <https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932>
 - <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930>
 - <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928>
 - <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074931>
 - <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929>
 - <https://www.oracle.com//security-alerts/cpujul2021.html>
 - <https://www.oracle.com/security-alerts/cpuoct2021.html>
 - <https://www.oracle.com/security-alerts/cpujan2022.html>

- <https://www.oracle.com/security-alerts/cpujul2022.html>
- <https://cert-portal.siemens.com/productcert/pdf/ssa-637483.pdf>
- <https://security.netapp.com/advisory/ntap-20210312-0006>
- <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2021-23337.yml>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2021-23337>

Related Vulnerability URLs:

- <https://cert-portal.siemens.com/productcert/pdf/ssa-637483.pdf>
- <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js%23L14851>
- <https://security.netapp.com/advisory/ntap-20210312-0006/>
- <https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932>
- <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930>
- <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928>
- <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074931>
- <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929>
- <https://snyk.io/vuln/SNYK-JS-LODASH-1040724>
- <https://www.oracle.com//security-alerts/cpujul2021.html>
- <https://www.oracle.com/security-alerts/cpujan2022.html>
- <https://www.oracle.com/security-alerts/cpujul2022.html>
- <https://www.oracle.com/security-alerts/cpuoct2021.html>

Finding 41: GHSA-3h5v-q93c-6h6q in ws:7.4.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.54% / 67.23%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
ws	7.4.6

File Path
/juice-shop/node_modules/engine.io/node_modules/ws/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: ws affected by a DoS when handling a request with many HTTP headers

Related Vulnerability Description: ws is an open source WebSocket client and server for Node.js. A request with a number of headers exceeding `server.maxHeadersCount` threshold could be used to crash a ws server. The vulnerability was fixed in ws@8.17.1 (e55e510) and backported to ws@7.5.10 (22c2876), ws@6.2.3 (eeb76d3), and ws@5.2.4 (4abd8f6). In vulnerable versions of ws, the issue can be mitigated in the following ways: 1. Reduce the maximum allowed length of the request headers using the `--max-http-header-size=size` and/or the `maxHeaderSize` options so that no more headers than the `server.maxHeadersCount` limit can be sent. 2. Set `server.maxHeadersCount` to 0 so that no limit is applied.

Matcher: javascript-matcher

Package URL: pkg:npm/ws@7.4.6

Mitigation

Upgrade to version: 7.5.10

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3h5v-q93c-6h6q>

Vulnerability URLs:

- <https://github.com/websockets/ws/security/advisories/GHSA-3h5v-q93c-6h6q>
- <https://github.com/websockets/ws/issues/2230>
- <https://github.com/websockets/ws/pull/2231>
- <https://github.com/websockets/ws/commit/22c28763234aa75a7e1b76f5c01c181260d7917f>
- <https://github.com/websockets/ws/commit/4abd8f6de4b0b65ef80b3ff081989479ed93377e>
- <https://github.com/websockets/ws/commit/e55e5106f10fcbac37cfa89759e4cc0d073a52c>
- <https://github.com/websockets/ws/commit/eeb76d313e2a00dd5247ca3597bba7877d064a63>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-37890>

Related Vulnerability URLs:

- <https://github.com/websockets/ws/commit/22c28763234aa75a7e1b76f5c01c181260d7917f>
- <https://github.com/websockets/ws/commit/4abd8f6de4b0b65ef80b3ff081989479ed93377e>
- <https://github.com/websockets/ws/commit/e55e5106f10fcbac37cfa89759e4cc0d073a52c>
- <https://github.com/websockets/ws/commit/eeb76d313e2a00dd5247ca3597bba7877d064a63>
- <https://github.com/websockets/ws/issues/2230>
- <https://github.com/websockets/ws/pull/2231>
- <https://github.com/websockets/ws/security/advisories/GHSA-3h5v-q93c-6h6q>
- <https://nodejs.org/api/http.html#servermaxheaderscount>

Finding 132: GHSA-8qq5-rm4j-mr97 in tar:4.4.19

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.28%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	4.4.19

File Path
/juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript**Vulnerability Description:** node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization**Related Vulnerability Description:** node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.**Matcher:** javascript-matcher**Package URL:** pkg:npm/tar@4.4.19

Mitigation

Upgrade to version: 7.5.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8qq5-rm4j-mr97>**Vulnerability URLs:**

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>
- <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>**Related Vulnerability URLs:**

- <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>

Finding 43: GHSA-cgfm-xwp7-2cvr in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.45% / 63.13%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Sanitize-html Vulnerable To REDoS Attacks

Related Vulnerability Description: The package sanitize-html before 2.7.1 are vulnerable to Regular Expression Denial of Service (ReDoS) due to insecure global regular expression replacement logic of HTML comment removal.

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 2.7.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-cgfm-xwp7-2cvr>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2022-25887>
- <https://github.com/apostrophecms/sanitize-html/pull/557>
- <https://github.com/apostrophecms/sanitize-html/commit/b4682c12fd30e12e82fa2d9b766de91d7d2cd23c>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3008102>
- <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-2957526>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-25887>

Related Vulnerability URLs:

- <https://github.com/apostrophecms/sanitize-html/commit/b4682c12fd30e12e82fa2d9b766de91d7d2cd23c>

Finding 131: GHSA-r6q2-hw4h-h46w in tar:7.4.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.31%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	7.4.3

File Path
/juice-shop/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS

Related Vulnerability Description: node-tar, a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@7.4.3

Mitigation

Upgrade to version: 7.5.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-r6q2-hw4h-h46w>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>
- <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcbce0a0df5954d390521e6>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcbce0a0df5954d390521e6>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>

Finding 45: GHSA-4xc9-xhrj-v574 in lodash:2.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.34% / 56.63%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
lodash	2.4.2

File Path
/juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Prototype Pollution in lodash

Related Vulnerability Description: A prototype pollution vulnerability was found in lodash <4.17.11 where the functions merge, mergeWith, and defaultsDeep can be tricked into adding or modifying properties of Object.prototype.

Matcher: javascript-matcher

Package URL: pkg:npm/lodash@2.4.2

Mitigation

Upgrade to version: 4.17.11

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-4xc9-xhrj-v574>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2018-16487>

- <https://hackerone.com/reports/380873>
- <https://github.com/lodash/lodash/commit/90e6199a161b6445b01454517b40ef65ebecd2ad>
- <https://security.netapp.com/advisory/ntap-20190919-0004>
- <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-16487.yml>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2018-16487>

Related Vulnerability URLs:

- <https://hackerone.com/reports/380873>
- <https://security.netapp.com/advisory/ntap-20190919-0004/>

Finding 130: GHSA-r6q2-hw4h-h46w in tar:6.2.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.31%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	6.2.1

File Path
/juice-shop/node_modules/sqlite3/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS

Related Vulnerability Description: node-tar, a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@6.2.1

Mitigation

Upgrade to version: 7.5.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-r6q2-hw4h-h46w>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>
- <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>

Finding 47: GHSA-446m-mv8f-q348 in moment:2.0.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.31% / 53.93%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
moment	2.0.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Regular Expression Denial of Service in moment

Related Vulnerability Description: The moment module before 2.19.3 for Node.js is prone to a regular expression denial of service via a crafted date string, a different vulnerability than CVE-2016-4055.

Matcher: javascript-matcher

Package URL: pkg:npm/moment@2.0.0

Mitigation

Upgrade to version: 2.19.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-446m-mv8f-q348>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2017-18214>
- <https://github.com/moment/moment/issues/4163>
- <https://github.com/moment/moment/pull/4326>
- <https://www.npmjs.com/advisories/532>
- <https://www.tenable.com/security/tns-2019-02>
- <https://github.com/moment/moment/commit/69ed9d44957fa6ab12b73d2ae29d286a857b80eb>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2017-18214>

Related Vulnerability URLs:

- <https://github.com/moment/moment/issues/4163>
- <https://nodesecurity.io/advisories/532>
- <https://www.tenable.com/security/tns-2019-02>

Finding 144: GHSA-gjcw-v447-2w7q in jws:0.2.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	N.A. / N.A.	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jws	0.2.6

File Path
/juice-shop/node_modules/jws/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Forgeable Public/Private Tokens in jws

Matcher: javascript-matcher

Package URL: pkg:npm/jws@0.2.6

Mitigation

Upgrade to version: 3.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-gjcw-v447-2w7q>

Vulnerability URLs:

- <https://github.com/brianloveswords/node-jws/commit/585d0e1e97b6747c10cf5b7689ccc5618a89b299#diff-4ac32a78649ca5bdd8e0ba38b7006a1e>
- <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- <https://www.npmjs.com/advisories/88>
- <https://nvd.nist.gov/vuln/detail/CVE-2016-1000223>
- <https://snyk.io/vuln/npm:jws:20160726>

Related Vulnerability Datasource: nvd

Finding 129: GHSA-r6q2-hw4h-h46w in tar:4.4.19

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.31%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	4.4.19

File Path
/juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS

Related Vulnerability Description: node-tar, a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have

04.04.2026, 23:54

Finding Report

their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@4.4.19

Mitigation

Upgrade to version: 7.5.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-r6q2-hw4h-h46w>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>
- <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>

Finding 50: GHSA-grv7-fg5c-xmjpg in braces:2.3.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.22% / 44.92%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
braces	2.3.2

File Path
/juice-shop/node_modules/braces/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Uncontrolled resource consumption in braces

Related Vulnerability Description: The NPM package braces, versions prior to 3.0.3, fails to limit the number of characters it can handle, which could lead to Memory Exhaustion. In lib/parse.js, if a malicious user sends "imbalanced braces" as input, the parsing will enter a loop, which will cause the program to start allocating heap memory without freeing it at any moment of the loop. Eventually, the JavaScript heap limit is reached, and the program will crash.

Matcher: javascript-matcher

Package URL: pkg:npm/braces@2.3.2

Mitigation

Upgrade to version: 3.0.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-grv7-fg5c-xmjb>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2024-4068>
- <https://github.com/micromatch/braces/issues/35>
- <https://devhub.checkmarx.com/cve-details/CVE-2024-4068>
- <https://github.com/micromatch/braces/blob/98414f9f1fabe021736e26836d8306d5de747e0d/lib/parse.js#L308>
- <https://github.com/micromatch/braces/pull/37>
- <https://github.com/micromatch/braces/pull/40>
- <https://github.com/micromatch/braces/commit/415d660c3002d1ab7e63dbf490c9851da80596ff>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-4068>

Related Vulnerability URLs:

- <https://devhub.checkmarx.com/cve-details/CVE-2024-4068/>
- <https://github.com/micromatch/braces/commit/415d660c3002d1ab7e63dbf490c9851da80596ff>
- <https://github.com/micromatch/braces/issues/35>
- <https://github.com/micromatch/braces/pull/37>
- <https://github.com/micromatch/braces/pull/40>

Finding 51: GHSA-6g6m-m6h5-w9gf in express-jwt:0.1.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.22% / 44.60%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
express-jwt	0.1.3

File Path
/juice-shop/node_modules/express-jwt/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Authorization bypass in express-jwt

Related Vulnerability Description: In express-jwt (NPM package) up and including version 5.3.3, the algorithms entry to be specified in the configuration is not being enforced. When algorithms is not specified in the configuration, with the combination of jwks-rsa, it may lead to authorization bypass. You are affected by this vulnerability if all of the following conditions apply: - You are using express-jwt - You do not have **algorithms** configured in your express-jwt configuration. - You are using libraries such as jwks-rsa as the **secret**. You can fix this by specifying **algorithms** in the express-jwt configuration. See linked GHSA for example. This is also fixed in version 6.0.0.

Matcher: javascript-matcher

Package URL: pkg:npm/express-jwt@0.1.3

Mitigation

Upgrade to version: 6.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-6g6m-m6h5-w9gf>

Vulnerability URLs:

- <https://github.com/auth0/express-jwt/security/advisories/GHSA-6g6m-m6h5-w9gf>
- <https://github.com/auth0/express-jwt/commit/7ecab5f8f0cab5297c2b863596566eb0c019cdef>
- <https://nvd.nist.gov/vuln/detail/CVE-2020-15084>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2020-15084>

Related Vulnerability URLs:

- <https://github.com/auth0/express-jwt/commit/7ecab5f8f0cab5297c2b863596566eb0c019cdef>
- <https://github.com/auth0/express-jwt/security/advisories/GHSA-6g6m-m6h5-w9gf>

Finding 127: CVE-2026-0861 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.64%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Passing too large an alignment to the memalign suite of functions (memalign, posix_memalign, aligned_alloc) in the GNU C Library version 2.30 to 2.42 may result in an integer overflow, which could consequently result in a heap corruption. Note that the attacker must have control over both, the size as well as the alignment arguments of the memalign function to be able to exploit this. The size parameter must be close enough to PTRDIFF_MAX so as to overflow size_t along with the large alignment argument. This limits the malicious inputs for the alignment for memalign to the range [1<<62+ 1, 1<<63] and exactly 1<<63 for posix_memalign and aligned_alloc. Typically the alignment argument passed to such functions is a known constrained quantity (e.g. page size, block size, struct sizes) and is not attacker controlled, because of which this may not be easily exploitable in practice. An application bug could potentially result in the input alignment being too large, e.g. due to a different buffer overflow or integer overflow in the application or its dependent libraries, but that is again an uncommon usage pattern given typical sources of alignments.

Related Vulnerability Description: Passing too large an alignment to the memalign suite of functions (memalign, posix_memalign, aligned_alloc) in the GNU C Library version 2.30 to 2.42 may result in an integer overflow, which could consequently result in a heap corruption.

Note that the attacker must have control over both, the size as well as the alignment arguments of the memalign function to be able to exploit this. The size parameter must be close enough to PTRDIFF_MAX so as to overflow size_t along with the large alignment argument. This limits the malicious inputs for the alignment for memalign to the range [1<<62+ 1, 1<<63] and exactly 1<<63 for posix_memalign and aligned_alloc.

Typically the alignment argument passed to such functions is a known constrained quantity (e.g. page size, block size, struct sizes) and is not attacker controlled, because of which this may not be easily exploitable in practice. An application bug could potentially result in the input alignment being too large, e.g. due to a different buffer overflow or integer overflow in the application or its dependent libraries, but that is again an uncommon usage pattern given typical sources of alignments.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2026-0861>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-0861>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=33796
- https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0001
- <http://www.openwall.com/lists/oss-security/2026/01/16/5>

Finding 125: GHSA-869p-cjfg-cm3x in jws:0.2.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 0.90%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jws	0.2.6

File Path
/juice-shop/node_modules/jws/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: auth0/node-jws Improperly Verifies HMAC Signature

Related Vulnerability Description: auth0/node-jws is a JSON Web Signature implementation for Node.js. In versions 3.2.2 and earlier and version 4.0.0, auth0/node-jws has an improper signature verification vulnerability when using the HS256 algorithm under specific conditions. Applications are affected when they use the jws.createVerify() function for HMAC algorithms and use user-provided data from the JSON Web Signature protected header or payload in HMAC secret lookup routines, which can allow attackers to bypass signature verification. This issue has been patched in versions 3.2.3 and 4.0.1.

Matcher: javascript-matcher

Package URL: pkg:npm/jws@0.2.6

Mitigation

Upgrade to version: 3.2.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-869p-cjfg-cm3x>

Vulnerability URLs:

- <https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x>
- <https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e>
- <https://github.com/auth0/node-jws/commit/4f6e73f24df42f07d632dec6431ade8eda8d11a6>

- <https://github.com/auth0/node-jws/releases/tag/v3.2.3>
- <https://github.com/auth0/node-jws/releases/tag/v4.0.1>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-65945>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-65945>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e>
- <https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x>

Finding 54: GHSA-rc47-6667-2j5j in http-cache-semantics:3.8.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.20% / 41.47%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
http-cache-semantics	3.8.1

File Path
/juice-shop/node_modules/http-cache-semantics/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: http-cache-semantics vulnerable to Regular Expression Denial of Service

Related Vulnerability Description: This affects versions of the package http-cache-semantics before 4.1.1. The issue can be exploited via malicious request header values sent to a server, when that server reads the cache policy from the request using this library.

Matcher: javascript-matcher

Package URL: pkg:npm/http-cache-semantics@3.8.1

Mitigation

Upgrade to version: 4.1.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-rc47-6667-2j5j>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2022-25881>

- <https://github.com/kornelski/http-cache-semantics/blob/master/index.js%23L83>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3253332>
- <https://security.snyk.io/vuln/SNYK-JS-HTTPCACHESEMANTICS-3248783>
- <https://github.com/kornelski/http-cache-semantics/commit/560b2d8ef452bbba20ffed69dc155d63ac757b74>
- <https://security.netapp.com/advisory/ntap-20230622-0008>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-25881>

Related Vulnerability URLs:

- <https://github.com/kornelski/http-cache-semantics/blob/master/index.js%23L83>
- <https://security.netapp.com/advisory/ntap-20230622-0008/>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3253332>
- <https://security.snyk.io/vuln/SNYK-JS-HTTPCACHESEMANTICS-3248783>

Finding 122: GHSA-4pg4-qvpc-4q3h in multer:1.4.5-lts.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.36%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
multer	1.4.5-lts.2

File Path
/juice-shop/node_modules/multer/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Multer vulnerable to Denial of Service from maliciously crafted requests

Related Vulnerability Description: Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.0 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.0 to receive a patch. No known workarounds are available.

Matcher: javascript-matcher

Package URL: pkg:npm/multer@1.4.5-lts.2

Mitigation

Upgrade to version: 2.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-4pg4-qvpc-4q3h>

Vulnerability URLs:

- <https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-47944>
- <https://github.com/expressjs/multer/issues/1176>
- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-47944>

Related Vulnerability URLs:

- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>
- <https://github.com/expressjs/multer/issues/1176>
- <https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h>

Finding 121: GHSA-83g3-92jg-28cx in tar:7.4.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.74%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	7.4.3

File Path
/juice-shop/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction

Related Vulnerability Description: node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@7.4.3

Mitigation

Upgrade to version: 7.5.8

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-83g3-92jg-28cx>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

Finding 120: GHSA-83g3-92jg-28cx in tar:6.2.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.74%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	6.2.1

File Path
/juice-shop/node_modules/sqlite3/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction

Related Vulnerability Description: node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@6.2.1

Mitigation

Upgrade to version: 7.5.8

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-83g3-92jg-28cx>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

Finding 119: GHSA-83g3-92jg-28cx in tar:4.4.19

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.74%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	4.4.19

File Path
/juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction

Related Vulnerability Description: node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections

and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@4.4.19

Mitigation

Upgrade to version: 7.5.8

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-83g3-92jg-28cx>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4ddddc153b0f536a19c050e7499f>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4ddddc153b0f536a19c050e7499f>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

Finding 100: CVE-2025-55131 in node:22.18.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.03% / 7.38%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
node	22.18.0

File Path
/nodejs/bin/node

CVSS v3

CVSS:3.0/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:L

Description

Vulnerability Namespace: nvd:cpe

Vulnerability Description: A flaw in Node.js's buffer allocation logic can expose uninitialized memory when allocations are interrupted, when using the vm module with the timeout option. Under specific timing conditions, buffers allocated with

Matcher: stock-matcher

Package URL: pkg:generic/node@22.18.0

Mitigation

Upgrade to version:

- 20.20.0
- 22.22.0
- 24.13.0
- 25.3.0

References

Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-55131>

Vulnerability URL: <https://nodejs.org/en/blog/vulnerability/december-2025-security-releases>

Finding 60: GHSA-6rw7-vpxm-498p in qs:6.13.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.08% / 24.59%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
qs	6.13.0

File Path
/juice-shop/node_modules/qs/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: qs's arrayLimit bypass in its bracket notation allows DoS via memory exhaustion

Related Vulnerability Description: Improper Input Validation vulnerability in qs (parse modules) allows HTTP DoS.This issue affects qs: < 6.14.1.

Summary

The `arrayLimit` option in `qs` did not enforce limits for bracket notation (`a[]=1&a[]=2`), only for indexed notation (`a[0]=1`). This is a consistency bug; `arrayLimit` should apply uniformly across all array notations.

Note: The default `parameterLimit` of 1000 effectively mitigates the DoS scenario originally described. With default options, bracket notation cannot produce arrays larger than `parameterLimit` regardless of `arrayLimit`, because each `a[]=value` consumes one parameter slot. The severity has been reduced accordingly.

Details

The `arrayLimit` option only checked limits for indexed notation (`a[0]=1&a[1]=2`) but did not enforce it for bracket notation (`a[]=1&a[]=2`).

Vulnerable code (`lib/parse.js:159-162`):

```
if (root === '[]' && options.parseArrays) {  
  
  obj = utils.combine([], leaf); // No arrayLimit check  
  
}
```

Working code (`lib/parse.js:175`):

```
else if (index <= options.arrayLimit) { // Limit checked here  
  
  obj = [];  
  
  obj[index] = leaf;  
  
}
```

The bracket notation handler at line 159 uses `utils.combine([], leaf)` without validating against `options.arrayLimit`, while indexed notation at line 175 checks `index <= options.arrayLimit` before creating arrays.

PoC

```
const qs = require('qs');  
  
const result = qs.parse('a[]=1&a[]=2&a[]=3&a[]=4&a[]=5&a[]=6', { arrayLimit: 5 });  
  
console.log(result.a.length); // Output: 6 (should be max 5)
```

Note on `parameterLimit` interaction: The original advisory's "DoS demonstration" claimed a length of 10,000, but `parameterLimit` (default: 1000) caps parsing to 1,000 parameters. With default options, the actual output is 1,000, not 10,000.

Impact

Consistency bug in `arrayLimit` enforcement. With default `parameterLimit`, the practical DoS risk is negligible since `parameterLimit` already caps the total number of parsed parameters (and thus array elements from bracket notation). The risk increases only when `parameterLimit` is explicitly set to a very high value.

Matcher: javascript-matcher

Package URL: pkg:npm/qs@6.13.0

Mitigation

Upgrade to version: 6.14.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-6rw7-vpxm-498p>

Vulnerability URLs:

- <https://github.com/ljharb/qs/security/advisories/GHSA-6rw7-vpxm-498p>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-15284>
- <https://github.com/ljharb/qs/commit/3086902ecf7f088d0d1803887643ac6c03d415b9>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-15284>

Related Vulnerability URLs:

- <https://github.com/ljharb/qs/commit/3086902ecf7f088d0d1803887643ac6c03d415b9>
- <https://github.com/ljharb/qs/security/advisories/GHSA-6rw7-vpxm-498p>

Finding 61: GHSA-g5hg-p3ph-g8qg in multer:1.4.5-lts.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.08% / 23.71%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
multer	1.4.5-lts.2

File Path
/juice-shop/node_modules/multer/package.json

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Multer vulnerable to Denial of Service via unhandled exception

Related Vulnerability Description: Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.1 allows an attacker to trigger a Denial of Service (DoS) by sending an upload file request with an empty string field name. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to 2.0.1 to receive a patch. No known workarounds are available.

Matcher: javascript-matcher

Package URL: pkg:npm/multer@1.4.5-lts.2

Mitigation

Upgrade to version: 2.0.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-g5hg-p3ph-g8qg>

Vulnerability URLs:

- <https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qg>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-48997>
- <https://github.com/expressjs/multer/issues/1233>
- <https://github.com/expressjs/multer/pull/1256>
- <https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-48997>

Related Vulnerability URLs:

- <https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9>
- <https://github.com/expressjs/multer/issues/1233>
- <https://github.com/expressjs/multer/pull/1256>
- <https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qg>

Finding 118: GHSA-fjgf-rc76-4x9p in multer:1.4.5-lts.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.41%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
multer	1.4.5-lts.2

File Path
/juice-shop/node_modules/multer/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Multer vulnerable to Denial of Service via unhandled exception from malformed request

Related Vulnerability Description: Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.2 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.2 to receive a patch. No known workarounds are available.

Matcher: javascript-matcher

Package URL: pkg:npm/multer@1.4.5-lts.2

Mitigation

Upgrade to version: 2.0.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-fjgf-rc76-4x9p>

Vulnerability URLs:

- <https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-7338>
- <https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b>
- <https://cna.openjsf.org/security-advisories.html>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-7338>

Related Vulnerability URLs:

- <https://cna.openjsf.org/security-advisories.html>
- <https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b>
- <https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p>

Finding 98: GHSA-vj76-c3g6-qr5v in tar-fs:2.1.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.03% / 7.12%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar-fs	2.1.3

File Path
/juice-shop/node_modules/tar-fs/package.json

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: tar-fs has a symlink validation bypass if destination directory is predictable with a specific tarball

Related Vulnerability Description: tar-fs provides filesystem bindings for tar-stream. Versions prior to 3.1.1, 2.1.3, and 1.16.5 are vulnerable to symlink validation bypass if the destination directory is predictable with a specific tarball. This issue has been patched in version 3.1.1, 2.1.4, and 1.16.6. A workaround involves using the ignore option on non files/directories.

Matcher: javascript-matcher

Package URL: pkg:npm/tar-fs@2.1.3

Mitigation

Upgrade to version: 2.1.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-vj76-c3g6-qr5v>

Vulnerability URLs:

- <https://github.com/mafintosh/tar-fs/security/advisories/GHSA-vj76-c3g6-qr5v>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-59343>
- <https://github.com/mafintosh/tar-fs/commit/0bd54cdf06da2b7b5b95cd4b062c9f4e0a8c4e09>
- <https://lists.debian.org/debian-lts-announce/2025/09/msg00028.html>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-59343>

Related Vulnerability URLs:

- <https://github.com/mafintosh/tar-fs/commit/0bd54cdf06da2b7b5b95cd4b062c9f4e0a8c4e09>
- <https://github.com/mafintosh/tar-fs/security/advisories/GHSA-vj76-c3g6-qr5v>
- <https://lists.debian.org/debian-lts-announce/2025/09/msg00028.html>

Finding 64: GHSA-8cf7-32gw-wr33 in jsonwebtoken:0.1.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.07% / 21.94%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.1.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsonwebtoken unrestricted key type could lead to legacy keys usage

Related Vulnerability Description: Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has

04.04.2026, 23:54

Finding Report

been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Matcher: javascript-matcher

Package URL: pkg:npm/jsonwebtoken@0.1.0

Mitigation

Upgrade to version: 9.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8cf7-32gw-wr33>

Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>
- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>
- <https://security.netapp.com/advisory/ntap-20240621-0007>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>

Finding 65: GHSA-8cf7-32gw-wr33 in jsonwebtoken:0.4.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.07% / 21.94%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.4.0

File Path
/juice-shop/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsonwebtoken unrestricted key type could lead to legacy keys usage

Related Vulnerability Description: Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Matcher: javascript-matcher

Package URL: pkg:npm/jsonwebtoken@0.4.0

Mitigation

Upgrade to version: 9.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8cf7-32gw-wr33>

Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>
- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>
- <https://security.netapp.com/advisory/ntap-20240621-0007>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>

Finding 66: GHSA-vghf-hv5q-vc2g in validator:13.15.15

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.07% / 22.32%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
validator	13.15.15

File Path
/juice-shop/node_modules/validator/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Validator is Vulnerable to Incomplete Filtering of One or More Instances of Special Elements

Related Vulnerability Description: Versions of the package validator before 13.15.22 are vulnerable to Incomplete Filtering of One or More Instances of Special Elements in the isLength() function that does not take into account Unicode variation selectors (\uFE0F, \uFE0E) appearing in a sequence which lead to improper string length calculation. This can lead to an application using isLength for input validation accepting strings significantly longer than intended, resulting in issues like data truncation in databases, buffer overflows in other system components, or denial-of-service.

Matcher: javascript-matcher

Package URL: pkg:npm/validator@13.15.15

Mitigation

Upgrade to version: 13.15.22

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-vghf-hv5q-vc2g>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2025-12758>
- <https://github.com/validatorjs/validator.js/pull/2616>
- <https://gist.github.com/koral--/ad31208b25b9e3d1e2e35f1d4d72572e>
- <https://security.snyk.io/vuln/SNYK-JS-VALIDATOR-13653476>
- <https://github.com/validatorjs/validator.js/commit/d457ecaf55b0f3d8bd379d82757425d0d13dd382>
- <http://seclists.org/fulldisclosure/2026/Jan/27>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-12758>

Related Vulnerability URLs:

- <https://gist.github.com/koral--/ad31208b25b9e3d1e2e35f1d4d72572e>
- <https://github.com/validatorjs/validator.js/pull/2616>
- <https://security.snyk.io/vuln/SNYK-JS-VALIDATOR-13653476>
- <http://seclists.org/fulldisclosure/2026/Jan/27>

Finding 67: CVE-2025-69420 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.07% / 21.29%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: A type confusion vulnerability exists in the TimeStamp Response verification code where an ASN1_TYPE union member is accessed without first validating the type, causing an invalid or NULL pointer dereference when processing a malformed TimeStamp Response file. Impact summary: An application calling TS_RESP_verify_response() with a malformed TimeStamp Response can be caused to dereference an invalid or NULL pointer when reading, resulting in a Denial of Service. The functions openssl_get_signing_cert() and openssl_get_signing_cert_v2() access the signing cert attribute value without validating its type. When the type is not V_ASN1_SEQUENCE, this results in accessing invalid memory through the ASN1_TYPE union, causing a crash. Exploiting this vulnerability requires an attacker to provide a malformed TimeStamp Response to an application that verifies timestamp responses. The TimeStamp protocol (RFC 3161) is not widely used and the impact of the exploit is just a Denial of Service. For these reasons the issue was assessed as Low severity. The FIPS modules in 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the TimeStamp Response implementation is outside the OpenSSL FIPS module boundary. OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue. OpenSSL 1.0.2 is not affected by this issue.

Related Vulnerability Description: Issue summary: A type confusion vulnerability exists in the TimeStamp Response verification code where an ASN1_TYPE union member is accessed without first validating the type, causing an invalid or NULL pointer dereference when processing a malformed TimeStamp Response file.

Impact summary: An application calling TS_RESP_verify_response() with a malformed TimeStamp Response can be caused to dereference an invalid or NULL pointer when reading, resulting in a Denial of Service.

The functions openssl_get_signing_cert() and openssl_get_signing_cert_v2() access the signing cert attribute value without validating its type. When the type is not V_ASN1_SEQUENCE, this results in accessing invalid memory through the ASN1_TYPE union, causing a crash.

Exploiting this vulnerability requires an attacker to provide a malformed TimeStamp Response to an application that verifies timestamp responses. The TimeStamp protocol (RFC 3161) is not widely used and the impact of the

exploit is just a Denial of Service. For these reasons the issue was assessed as Low severity.

The FIPS modules in 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the TimeStamp Response implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue.

OpenSSL 1.0.2 is not affected by this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-69420>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-69420>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/27c7012c91cc986a598d7540f3079dfde2416eb9>
- <https://github.com/openssl/openssl/commit/4e254b48ad93cc092be3dd62d97015f33f73133a>
- <https://github.com/openssl/openssl/commit/564fd9c73787f25693bf9e75faf7bf6bb1305d4e>
- <https://github.com/openssl/openssl/commit/5eb0770ffcf11b785cf374ff3c19196245e54f1b>
- <https://github.com/openssl/openssl/commit/a99349ebfc519999edc50620abe24d599b9eb085>
- <https://openssl-library.org/news/secadv/20260127.txt>

Finding 68: CVE-2025-59465 in node:22.18.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.07% / 21.03%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
node	22.18.0

File Path
/nodejs/bin/node

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: nvd:cpe

Vulnerability Description: A malformed HTTP/2 HEADERS frame with oversized, invalid HPACK data can cause Node.js to crash by triggering an unhandled TLSSocket error ECONNRESET. Instead of safely closing the connection, the process crashes, enabling a remote denial of service. This primarily affects applications that do not attach explicit error handlers to secure sockets, for example:

```
server.on('secureConnection', socket => {
  socket.on('error', err => {
    console.log(err)
  })
})
```

Matcher: stock-matcher

Package URL: pkg:generic/node@22.18.0

Mitigation

Upgrade to version:

- 20.20.0
- 22.22.0
- 24.13.0
- 25.3.0

References

Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-59465>

Vulnerability URL: <https://nodejs.org/en/blog/vulnerability/december-2025-security-releases>

Finding 69: CVE-2025-69421 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.06% / 18.43%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: Processing a malformed PKCS#12 file can trigger a NULL pointer dereference in the PKCS12_item_decrypt_d2i_ex() function. Impact summary: A NULL pointer dereference can trigger a crash which leads to Denial of Service for an application processing PKCS#12 files. The PKCS12_item_decrypt_d2i_ex() function does not check whether the oct parameter is NULL before dereferencing it. When called from PKCS12_unpack_p7encdata() with a malformed PKCS#12 file, this parameter can be NULL, causing a crash. The vulnerability is limited to Denial of Service and cannot be escalated to achieve code execution or memory disclosure. Exploiting this issue requires an attacker to provide a malformed PKCS#12 file to an application that processes it. For that reason the issue was assessed as Low severity according to our Security Policy. The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS#12 implementation is outside the OpenSSL FIPS module boundary. OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0, 1.1.1 and 1.0.2 are vulnerable to this issue.

Related Vulnerability Description: Issue summary: Processing a malformed PKCS#12 file can trigger a NULL pointer dereference in the PKCS12_item_decrypt_d2i_ex() function.

Impact summary: A NULL pointer dereference can trigger a crash which leads to

Denial of Service for an application processing PKCS#12 files.

The PKCS12_item_decrypt_d2i_ex() function does not check whether the oct

parameter is NULL before dereferencing it. When called from

PKCS12_unpack_p7encdata() with a malformed PKCS#12 file, this parameter can

be NULL, causing a crash. The vulnerability is limited to Denial of Service

and cannot be escalated to achieve code execution or memory disclosure.

Exploiting this issue requires an attacker to provide a malformed PKCS#12 file

to an application that processes it. For that reason the issue was assessed as

Low severity according to our Security Policy.

The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue,

as the PKCS#12 implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0, 1.1.1 and 1.0.2 are vulnerable to this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-69421>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-69421>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/3524a29271f8191b8fd8a5257eb05173982a097b>
- <https://github.com/openssl/openssl/commit/36ecb4960872a4ce04bf6f1e1f4e78d75ec0c0c7>
- <https://github.com/openssl/openssl/commit/4bbc8d41a72c842ce4077a8a3eccd1109aaf74bd>
- <https://github.com/openssl/openssl/commit/643986985cd1c21221f941129d76fe0c2785aeb3>
- <https://github.com/openssl/openssl/commit/a2dbc539f0f9cc63832709fa5aa33ad9495eb19c>
- <https://openssl-library.org/news/secadv/20260127.txt>

Finding 96: CVE-2026-21637 in node:22.18.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.03% / 10.23%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
node	22.18.0

File Path
/nodejs/bin/node

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: nvd:cpe

Vulnerability Description: A flaw in Node.js TLS error handling allows remote attackers to crash or exhaust resources of a TLS server when pskCallback or ALPNCallback are in use. Synchronous exceptions thrown during these callbacks bypass standard TLS error handling paths (tlsClientError and error), causing either immediate process termination or silent file descriptor leaks that eventually lead to denial of service. Because these callbacks process attacker-controlled input during the TLS handshake, a remote client can repeatedly trigger the issue. This vulnerability affects TLS servers using PSK or ALPN callbacks across Node.js versions where these callbacks throw without being safely wrapped.

Matcher: stock-matcher

Package URL: pkg:generic/node@22.18.0

Mitigation

Upgrade to version:

- 20.20.0
- 22.22.0

- 24.13.0

- 25.3.0

References

Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-21637>

Vulnerability URL: <https://nodejs.org/en/blog/vulnerability/december-2025-security-releases>

Finding 72: GHSA-3ppc-4f35-3m26 in minimatch:3.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 16.14%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.0.5

File Path
/juice-shop/node_modules/replace/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate *[^]? regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is $O(4^N)$ where N is the number of * characters. With $N=15$, a single minimatch() call takes ~2 seconds. With $N=34$, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.*

Matcher: javascript-matcher

Package URL. pkg:npm/minimatch@3.0.5*

Mitigation

Upgrade to version: 3.1.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3ppc-4f35-3m26>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

- <https://github.com/isaacs/minimatch/commit/2e11f3a79abc00fa73110195de2c0f2351904f5>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability URLs:

- <https://github.com/isaacs/minimatch/commit/2e11f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

Finding 74: GHSA-3ppc-4f35-3m26 in minimatch:3.1.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 16.14%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.1.2

File Path
/juice-shop/node_modules/rimraf/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate *[^]? regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is $O(4^N)$ where N is the number of * characters. With $N=15$, a single `minimatch()` call takes ~2 seconds. With $N=34$, it hangs effectively forever. Any application that passes user-controlled strings to `minimatch()` as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.*

Matcher: javascript-matcher

Package URL. pkg:npm/minimatch@3.1.2*

Mitigation

Upgrade to version: 3.1.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3ppc-4f35-3m26>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
- <https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability URLs:

- <https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

Finding 73: GHSA-3ppc-4f35-3m26 in minimatch:3.0.8

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 16.14%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.0.8

File Path
/juice-shop/node_modules/grunt/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate `[^]? regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is $O(4^N)$ where N is the number of * characters. With $N=15$, a single minimatch() call takes ~2 seconds. With $N=34$, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.`

Matcher: javascript-matcher

Package URL. pkg:npm/minimatch@3.0.8*

Mitigation

Upgrade to version: 3.1.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3ppc-4f35-3m26>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
- <https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability URLs:

- <https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

Finding 75: GHSA-3ppc-4f35-3m26 in minimatch:5.1.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 16.14%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	5.1.6

File Path
/juice-shop/node_modules/filehound/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate `[^]? regex group`, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is $O(4^N)$ where N is the number of * characters. With $N=15$, a single `minimatch()` call takes ~2 seconds. With $N=34$, it hangs effectively forever. Any application that passes user-controlled strings to `minimatch()` as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@5.1.6

Mitigation

Upgrade to version: 5.1.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3ppc-4f35-3m26>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
- <https://github.com/isaacs/minimatch/commit/2e11f3a79abc00fa73110195de2c0f2351904f5>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability URLs:

- <https://github.com/isaacs/minimatch/commit/2e11f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

Finding 76: GHSA-3ppc-4f35-3m26 in minimatch:9.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 16.14%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	9.0.5

File Path
/juice-shop/node_modules/glob/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate `[^]? regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is $O(4^N)$ where N is the number of * characters. With $N=15$, a single minimatch() call takes ~2 seconds. With $N=34$, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.`

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@9.0.5

Mitigation

Upgrade to version: 9.0.6

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3ppc-4f35-3m26>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
- <https://github.com/isaacs/minimatch/commit/2e11f3a79abc00fa73110195de2c0f2351904f5>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>

Related Vulnerability URLs:

- <https://github.com/isaacs/minimatch/commit/2e11f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

Finding 77: CVE-2025-69419 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.06% / 17.41%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: Calling PKCS12_get_friendlyname() function on a maliciously crafted PKCS#12 file with a BMPString (UTF-16BE) friendly name containing non-ASCII BMP code point can trigger a one byte write before the allocated buffer. Impact summary: The out-of-bounds write can cause a memory corruption which can have various consequences including a Denial of Service. The OPENSSL_uni2utf8() function performs a two-pass conversion of a PKCS#12 BMPString (UTF-16BE) to UTF-8. In the second pass, when emitting UTF-8 bytes, the helper function bmp_to_utf8() incorrectly forwards the remaining UTF-16 source byte count as the destination buffer capacity to UTF8_putc(). For BMP code points above U+07FF, UTF-8 requires three bytes, but the forwarded capacity can be just two bytes. UTF8_putc() then returns -1, and this negative value is added to the output length without validation, causing the length to become negative. The subsequent trailing NUL byte is then written at a negative offset, causing write outside of heap allocated buffer. The vulnerability is reachable via the public PKCS12_get_friendlyname() API when parsing attacker-controlled PKCS#12 files. While PKCS12_parse() uses a different code path that avoids this issue, PKCS12_get_friendlyname() directly invokes the vulnerable function. Exploitation requires an attacker to provide a malicious PKCS#12 file to be parsed by the application and the attacker can just trigger a one zero byte write before the allocated buffer. For that reason the issue was assessed as Low severity according to our Security Policy. The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS#12 implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue. OpenSSL 1.0.2 is not affected by this issue.

Related Vulnerability Description: Issue summary: Calling PKCS12_get_friendlyname() function on a maliciously crafted PKCS#12 file with a BMPString (UTF-16BE) friendly name containing non-ASCII BMP code point can trigger a one byte write before the allocated buffer.

Impact summary: The out-of-bounds write can cause a memory corruption which can have various consequences including a Denial of Service.

The OPENSSL_uni2utf8() function performs a two-pass conversion of a PKCS#12 BMPString (UTF-16BE) to UTF-8. In the second pass, when emitting UTF-8 bytes, the helper function bmp_to_utf8() incorrectly forwards the remaining UTF-16 source byte count as the destination buffer capacity to UTF8_putc(). For BMP code points above U+07FF, UTF-8 requires three bytes, but the forwarded capacity can be just two bytes. UTF8_putc() then returns -1, and this negative value is added to the output length without validation, causing the length to become negative. The subsequent trailing NUL byte is then written at a negative offset, causing write outside of heap allocated buffer.

The vulnerability is reachable via the public PKCS12_get_friendlyname() API when parsing attacker-controlled PKCS#12 files. While PKCS12_parse() uses a different code path that avoids this issue, PKCS12_get_friendlyname() directly invokes the vulnerable function. Exploitation requires an attacker to provide a malicious PKCS#12 file to be parsed by the application and the attacker can just trigger a one zero byte write before the allocated buffer.

For that reason the issue was assessed as Low severity according to our Security Policy.

The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS#12 implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue.

OpenSSL 1.0.2 is not affected by this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-69419>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-69419>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/41be0f216404f14457bbf3b9cc488dba60b49296>
- <https://github.com/openssl/openssl/commit/7e9cac9832e4705b91987c2474ed06a37a93cecb>
- <https://github.com/openssl/openssl/commit/a26a90d38edec3748566129d824e664b54bee2e2>
- <https://github.com/openssl/openssl/commit/cda12de3bc0e333ea8d2c6fd15001dbdaf280015>
- <https://github.com/openssl/openssl/commit/ff628933755075446bca8307e8417c14d164b535>
- <https://openssl-library.org/news/secadv/20260127.txt>

Finding 78: CVE-2025-15281 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 16.53%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Calling wordexp with WRDE_REUSE in conjunction with WRDE_APPEND in the GNU C Library version 2.0 to version 2.42 may cause the interface to return uninitialized memory in the we_wordv member, which on subsequent calls to wordfree may abort the process.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-15281>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-15281>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=33814
- <http://www.openwall.com/lists/oss-security/2026/01/20/3>

Finding 117: GHSA-34x7-hfp2-rc4v in tar:7.4.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.01% / 1.77%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	7.4.3

File Path
/juice-shop/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal

Related Vulnerability Description: node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@7.4.3

Mitigation

Upgrade to version: 7.5.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-34x7-hfp2-rc4v>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>

Finding 80: GHSA-44fp-w29j-9vj5 in multer:1.4.5-lts.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 14.84%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
multer	1.4.5-lts.2

File Path
/juice-shop/node_modules/multer/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Multer vulnerable to Denial of Service via memory leaks from unclosed streams

Related Vulnerability Description: Multer is a node.js middleware for handling multipart/form-data. Versions prior to 2.0.0 are vulnerable to a resource exhaustion and memory leak issue due to improper stream handling. When the HTTP request stream emits an error, the internal busboy stream is not closed, violating Node.js stream safety guidance. This leads to unclosed streams accumulating over time, consuming memory and file descriptors. Under sustained or repeated failure conditions, this can result in denial of service, requiring manual server restarts to recover. All users of Multer handling file uploads are potentially impacted. Users should upgrade to 2.0.0 to receive a patch. No known workarounds are available.

Matcher: javascript-matcher

Package URL: pkg:npm/multer@1.4.5-lts.2

Mitigation

Upgrade to version: 2.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-44fp-w29j-9vj5>

Vulnerability URLs:

- <https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5>

- <https://nvd.nist.gov/vuln/detail/CVE-2025-47935>
- <https://github.com/expressjs/multer/pull/1120>
- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-47935>

Related Vulnerability URLs:

- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>
- <https://github.com/expressjs/multer/pull/1120>
- <https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5>

Finding 81: GHSA-7r86-cg39-jmmj in minimatch:3.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 14.46%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.0.5

File Path
/juice-shop/node_modules/replace/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is O(C(n, k)) -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@3.0.5

Mitigation

Upgrade to version: 3.1.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-7r86-cg39-jmmj>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

Finding 82: GHSA-7r86-cg39-jmmj in minimatch:3.0.8

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 14.46%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.0.8

File Path
/juice-shop/node_modules/grunt/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is O(C(n, k)) -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@3.0.8

Mitigation

Upgrade to version: 3.1.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-7r86-cg39-jmmj>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

Finding 83: GHSA-7r86-cg39-jmmj in minimatch:3.1.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 14.46%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	3.1.2

File Path
/juice-shop/node_modules/sqlite3/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is O(C(n, k)) -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config

files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@3.1.2

Mitigation

Upgrade to version: 3.1.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-7r86-cg39-jmmj>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

Finding 84: GHSA-7r86-cg39-jmmj in minimatch:5.1.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
High	0.05% / 14.46%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
minimatch	5.1.6

File Path
/juice-shop/node_modules/filehound/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments

Related Vulnerability Description: minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is O(C(n, k)) -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call

budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Matcher: javascript-matcher

Package URL: pkg:npm/minimatch@5.1.6

Mitigation

Upgrade to version: 5.1.8

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-7r86-cg39-jmmj>

Vulnerability URLs:

- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

Related Vulnerability URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

Medium

Finding 145: GHSA-rvg8-pwq2-xj7q in base64url:0.0.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	N.A. / N.A.	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
base64url	0.0.6

File Path
/juice-shop/node_modules/base64url/package.json

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Out-of-bounds Read in base64url

Matcher: javascript-matcher

Package URL: pkg:npm/base64url@0.0.6

Mitigation

Upgrade to version: 3.0.0

References

Vulnerability Datasource: https://github.com/advisories/GHSA-rvg8-pwq2-xj7q

Vulnerability URLs:

- https://hackerone.com/reports/321687
- https://github.com/brianloveswords/base64url/pull/25
- https://github.com/brianloveswords/base64url/commit/4fbd954a0a69e9d898de2146557cc6e893e79542

Finding 9: Prometheus Metrics - Detect config exposure hackerone prometheus vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Medium	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Prometheus Metrics - Detect' on 'http://localhost:3000/metrics'	Active	March 6, 2026	April 4, 2026

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Prometheus metrics page was detected.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET /metrics HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.3.1 Safari/605.1.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Content-Length: 24532
Content-Type: text/plain; version=0.0.4; charset=utf-8
Date: Fri, 06 Mar 2026 16:54:01 GMT
# HELP file_uploads_count Total number of successful file uploads grouped by file type.
# TYPE file_uploads_count counter
```

04.04.2026, 23:54

Finding Report

```
# HELP file_upload_errors Total number of failed file uploads grouped by file type.
# TYPE file_upload_errors counter
# HELP juiceshop_startup_duration_seconds Duration juiceshop required to perform a certain task during startup
# TYPE juiceshop_startup_duration_seconds gauge
juiceshop_startup_duration_seconds{task="validateConfig",app="juiceshop"}
0.011778108
juiceshop_startup_duration_seconds{task="cleanupFtpFolder",app="juiceshop"}
0.026910677
juiceshop_startup_duration_seconds{task="validatePreconditions",app="juice...
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.3.1 Safari/605.1.15' 'http://localhost:3000/metrics'
```

References

<https://github.com/prometheus/prometheus>

<https://hackerone.com/reports/1026196>

Finding 32: GHSA-87vv-r9j6-g5qv in moment:2.0.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	4.05% / 88.30%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
moment	2.0.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Regular Expression Denial of Service in moment

Related Vulnerability Description: The duration function in the moment package before 2.11.2 for Node.js allows remote attackers to cause a denial of service (CPU consumption) via a long string, aka a "regular expression Denial of Service (ReDoS)."

Matcher: javascript-matcher

Package URL: pkg:npm/moment@2.0.0

Mitigation

Upgrade to version: 2.11.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-87vv-r9j6-g5qv>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2016-4055>
- <https://www.npmjs.com/advisories/55>
- <https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731@%3Cdev.flink.apache.org%3E>
- <https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49@%3Cuser.flink.apache.org%3E>
- <https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2@%3Cuser.flink.apache.org%3E>
- <https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854@%3Cuser.flink.apache.org%3E>
- <https://www.tenable.com/security/tns-2019-02>
- <http://www.openwall.com/lists/oss-security/2016/04/20/11>
- <http://www.oracle.com/technetwork/security-advisory/cpujul2018-4258247.html>
- <http://www.securityfocus.com/bid/95849>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2016-4055>

Related Vulnerability URLs:

- <http://www.openwall.com/lists/oss-security/2016/04/20/11>
- <http://www.oracle.com/technetwork/security-advisory/cpujul2018-4258247.html>
- <http://www.securityfocus.com/bid/95849>
- <https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731%40%3Cdev.flink.apache.org%3E>
- <https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49%40%3Cuser.flink.apache.org%3E>
- <https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2%40%3Cuser.flink.apache.org%3E>
- <https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854%40%3Cuser.flink.apache.org%3E>
- <https://nodesecurity.io/advisories/55>
- <https://www.tenable.com/security/tns-2019-02>

Finding 36: GHSA-r7qp-cfhv-p84w in engine.io:4.1.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	2.06% / 83.65%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
engine.io	4.1.2

File Path
/juice-shop/node_modules/engine.io/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Uncaught exception in engine.io

Related Vulnerability Description: Engine.IO is the implementation of transport-based cross-browser/cross-device bi-directional communication layer for Socket.IO. A specially crafted HTTP request can trigger an uncaught exception on the Engine.IO server, thus killing the Node.js process. This impacts all the users of the engine.io package, including those who uses depending packages like socket.io. There is no known workaround except upgrading to a safe version. There are patches for this issue released in versions 3.6.1 and 6.2.1.

Matcher: javascript-matcher

Package URL: pkg:npm/engine.io@4.1.2

Mitigation

Upgrade to version: 6.2.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-r7qp-cfhv-p84w>

Vulnerability URLs:

- <https://github.com/socketio/engine.io/security/advisories/GHSA-r7qp-cfhv-p84w>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-41940>
- <https://github.com/socketio/engine.io/commit/425e833ab13373edf1dd5a0706f07100db14e3c6>
- <https://github.com/socketio/engine.io/commit/83c4071af871fc188298d7d591e95670bf9f9085>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-41940>

Related Vulnerability URLs:

- <https://github.com/socketio/engine.io/commit/425e833ab13373edf1dd5a0706f07100db14e3c6>
- <https://github.com/socketio/engine.io/commit/83c4071af871fc188298d7d591e95670bf9f9085>
- <https://github.com/socketio/engine.io/security/advisories/GHSA-r7qp-cfhv-p84w>

Finding 38: GHSA-rm97-x556-q36h in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	1.34% / 79.77%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: sanitize-html Information Exposure vulnerability

Related Vulnerability Description: Versions of the package sanitize-html before 2.12.1 are vulnerable to Information Exposure when used on the backend and with the style attribute allowed, allowing enumeration of files in the system (including project dependencies). An attacker could exploit this vulnerability to gather details about the file system structure and dependencies of the targeted server.

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 2.12.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-rm97-x556-q36h>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2024-21501>
- <https://github.com/apostrophecms/sanitize-html/pull/650>
- <https://github.com/apostrophecms/sanitize-html/commit/c5dbdf77fe8b836d3bf4554ea39edb45281ec0b4>
- <https://gist.github.com/Slonser/8b4d061abe6ee1b2e10c7242987674cf>
- <https://github.com/apostrophecms/apostrophe/discussions/4436>
- <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-6256334>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6276557>

- <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7>

- <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-21501>

Related Vulnerability URLs:

- <https://gist.github.com/Slonser/8b4d061abe6ee1b2e10c7242987674cf>
- <https://github.com/apostrophecms/apostrophe/discussions/4436>
- <https://github.com/apostrophecms/sanitize-html/commit/c5dbdf77fe8b836d3bf4554ea39edb45281ec0b4>
- <https://github.com/apostrophecms/sanitize-html/pull/650>
- <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7/>
- <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S/>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6276557>
- <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-6256334>

Finding 42: GHSA-pfrx-2q88-qq97 in got:8.3.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.81% / 73.88%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
got	8.3.2

File Path
/juice-shop/node_modules/got/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Got allows a redirect to a UNIX socket

Related Vulnerability Description: The got package before 12.1.0 (also fixed in 11.8.5) for Node.js allows a redirect to a UNIX socket.

Matcher: javascript-matcher

Package URL: pkg:npm/got@8.3.2

Mitigation

Upgrade to version: 11.8.5

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-pfrx-2q88-qq97>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2022-33987>
- <https://github.com/sindresorhus/got/pull/2047>
- <https://github.com/sindresorhus/got/compare/v12.0.3...v12.1.0>
- <https://github.com/sindresorhus/got/commit/861ccd9ac2237df762a9e2beed7edd88c60782dc>
- <https://github.com/sindresorhus/got/releases/tag/v11.8.5>
- <https://github.com/sindresorhus/got/releases/tag/v12.1.0>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-33987>

Related Vulnerability URLs:

- <https://github.com/sindresorhus/got/compare/v12.0.3...v12.1.0>
- <https://github.com/sindresorhus/got/pull/2047>
- <https://github.com/sindresorhus/got/releases/tag/v11.8.5>

Finding 44: GHSA-p5gc-c584-jj6v in vm2:3.9.17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.57% / 68.16%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
vm2	3.9.17

File Path
/juice-shop/node_modules/vm2/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: vm2 vulnerable to Inspect Manipulation

Related Vulnerability Description: vm2 is a sandbox that can run untrusted code with Node's built-in modules. In versions 3.9.17 and lower of vm2 it was possible to get a read-write reference to the node inspect method and edit options for console.log. As a

04.04.2026, 23:54

Finding Report

result a threat actor can edit options for the console.log command. This vulnerability was patched in the release of version 3.9.18 of vm2. Users are advised to upgrade. Users unable to upgrade may make the inspect method readonly with vm.readonly(inspect) after creating a vm.

Matcher: javascript-matcher

Package URL: pkg:npm/vm2@3.9.17

Mitigation

Upgrade to version: 3.9.18

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-p5gc-c584-jj6v>

Vulnerability URLs:

- <https://github.com/patriksimek/vm2/security/advisories/GHSA-p5gc-c584-jj6v>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-32313>
- <https://github.com/patriksimek/vm2/commit/5206ba25afd86ef547a2c9d48d46ca7a9e6ec238>
- <https://gist.github.com/arkark/c1c57eaf3e0a649af1a70c2b93b17550>
- <https://github.com/patriksimek/vm2/releases/tag/3.9.18>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2023-32313>

Related Vulnerability URLs:

- <https://gist.github.com/arkark/c1c57eaf3e0a649af1a70c2b93b17550>
- <https://github.com/patriksimek/vm2/commit/5206ba25afd86ef547a2c9d48d46ca7a9e6ec238>
- <https://github.com/patriksimek/vm2/releases/tag/3.9.18>
- <https://github.com/patriksimek/vm2/security/advisories/GHSA-p5gc-c584-jj6v>

Finding 46: GHSA-f5x3-32g6-xq36 in tar:4.4.19

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.45% / 63.24%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
tar	4.4.19

File Path
/juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Denial of service while parsing a tar file due to lack of folders count validation

Related Vulnerability Description: node-tar is a Tar for Node.js. node-tar prior to version 6.2.1 has no limit on the number of sub-folders created in the folder creation process. An attacker who generates a large number of sub-folders can consume memory on the system running node-tar and even crash the Node.js client within few seconds of running it using a path with too many sub-folders inside. Version 6.2.1 fixes this issue by preventing extraction in excessively deep sub-folders.

Matcher: javascript-matcher

Package URL: pkg:npm/tar@4.4.19

Mitigation

Upgrade to version: 6.2.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-f5x3-32g6-xq36>

Vulnerability URLs:

- <https://github.com/isaacs/node-tar/security/advisories/GHSA-f5x3-32g6-xq36>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-28863>
- <https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7>
- <https://security.netapp.com/advisory/ntap-20240524-0005>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-28863>

Related Vulnerability URLs:

- <https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-f5x3-32g6-xq36>
- <https://security.netapp.com/advisory/ntap-20240524-0005/>

Finding 48: GHSA-3j7m-hmh3-9jmp in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.33% / 55.31%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Cross-Site Scripting in sanitize-html

Related Vulnerability Description: sanitize-html before 1.4.3 has XSS.

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 1.4.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-3j7m-hmh3-9jmp>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2016-1000237>
- <https://github.com/apostrophecms/sanitize-html/issues/29>
- <https://github.com/apostrophecms/sanitize-html/commit/762fbc7bba389f3f789cc291c1eb2b64f60f2caf>
- <https://raw.githubusercontent.com/distributedweaknessfiling/cvelist/master/2016/1000xxx/CVE-2016-1000237.json>
- <https://github.com/punkave/sanitize-html/issues/29>
- <https://www.npmjs.com/advisories/135>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2016-1000237>

Related Vulnerability URLs:

- <https://nodesecurity.io/advisories/135>
- <https://raw.githubusercontent.com/distributedweaknessfiling/cvelist/master/2016/1000xxx/CVE-2016-1000237.json>

Finding 49: GHSA-8g4m-cjm2-96wq in notevil:1.3.3

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.30% / 53.29%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
notevil	1.3.3

File Path
/juice-shop/node_modules/notevil/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Sandbox escape in notevil and argencoders-notevil

Related Vulnerability Description: This affects all versions of package notevil; all versions of package argencoders-notevil. It is vulnerable to Sandbox Escape leading to Prototype pollution. The package fails to restrict access to the main context, allowing an attacker to add or modify an object's prototype. **Note:** This vulnerability derives from an incomplete fix in [SNYK-JS-NOTEVIL-608878](#).

Matcher: javascript-matcher

Package URL: pkg:npm/notevil@1.3.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-8g4m-cjm2-96wq>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2021-23771>
- <https://snyk.io/vuln/SNYK-JS-ARGENCODERSNOTEVIL-2388587>
- <https://snyk.io/vuln/SNYK-JS-NOTEVIL-2385946>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2021-23771>

Related Vulnerability URLs:

- <https://snyk.io/vuln/SNYK-JS-ARGENCODERSNOTEVIL-2388587>
- <https://snyk.io/vuln/SNYK-JS-NOTEVIL-2385946>

Finding 52: GHSA-mjxr-4v3x-q3m4 in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.29% / 51.92%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Improper Input Validation in sanitize-html

Related Vulnerability Description: Apostrophe Technologies sanitize-html before 2.3.2 does not properly validate the hostnames set by the "allowedIframeHostnames" option when the "allowIframeRelativeUrls" is set to true, which allows attackers to bypass hostname whitelist for iframe element, related using an src value that starts with "/\example.com".

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 2.3.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-mjxr-4v3x-q3m4>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2021-26540>
- <https://github.com/apostrophecms/sanitize-html/pull/460>
- <https://advisory.checkmarx.net/advisory/CX-2021-4309>
- <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#232-2021-01-26>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2021-26540>

Related Vulnerability URLs:

- <https://advisory.checkmarx.net/advisory/CX-2021-4309>
- <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#232-2021-01-26>
- <https://github.com/apostrophecms/sanitize-html/pull/460>

Finding 53: GHSA-rjqj-98f6-6j3r in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.29% / 51.92%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Improper Input Validation in sanitize-html

Related Vulnerability Description: Apostrophe Technologies sanitize-html before 2.3.1 does not properly handle internationalized domain name (IDN) which could allow an attacker to bypass hostname whitelist validation set by the "allowedIframeHostnames" option.

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 2.3.1

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-rjqj-98f6-6j3r>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2021-26539>
- <https://github.com/apostrophecms/sanitize-html/pull/458>
- <https://advisory.checkmarx.net/advisory/CX-2021-4308>
- <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#231-2021-01-22>
- <https://github.com/apostrophecms/sanitize-html/commit/bdf7836ef8f0e5b21f9a1aab0623ae8fcd09c1da>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2021-26539>

Related Vulnerability URLs:

- <https://advisory.checkmarx.net/advisory/CX-2021-4308>

- <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#231-2021-01-22>
- <https://github.com/apostrophecms/sanitize-html/pull/458>

Finding 55: GHSA-fvqr-27wr-82fm in lodash:2.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.25% / 48.27%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
lodash	2.4.2

File Path
/juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Prototype Pollution in lodash

Related Vulnerability Description: lodash node module before 4.17.5 suffers from a Modification of Assumed-Immutable Data (MAID) vulnerability via defaultsDeep, merge, and mergeWith functions, which allows a malicious user to modify the prototype of "Object" via **proto**, causing the addition or modification of an existing property that will exist on all objects.

Matcher: javascript-matcher

Package URL: pkg:npm/lodash@2.4.2

Mitigation

Upgrade to version: 4.17.5

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-fvqr-27wr-82fm>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2018-3721>
- <https://hackerone.com/reports/310443>
- <https://github.com/lodash/lodash/commit/d8e069cc3410082e44eb18fcf8e7f3d08ebe1d4a>
- <https://security.netapp.com/advisory/ntap-20190919-0004>
- <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-3721.yml>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2018-3721>

Related Vulnerability URLs:

- <https://github.com/lodash/lodash/commit/d8e069cc3410082e44eb18fcf8e7f3d08ebe1d4a>
- <https://hackerone.com/reports/310443>
- <https://security.netapp.com/advisory/ntap-20190919-0004/>

Finding 56: GHSA-xc6g-ggrc-qq4r in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.29% / 51.68%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Cross-Site Scripting in sanitize-html

Related Vulnerability Description: Sanitize-html is a library for scrubbing html input of malicious values. Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios: If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 1.11.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-xc6g-ggrc-qq4r>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2017-16016>
- <https://github.com/punkave/sanitize-html/issues/100>
- [https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403\)\)\)](https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403))))
- <https://npmjs.com/package/sanitize-html#discarding-the-entire-contents-of-a-disallowed-tag>

- <https://www.npmjs.com/advisories/154>
- <https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2017-16016>

Related Vulnerability URLs:

- <https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403>
- <https://github.com/punkave/sanitize-html/issues/100>
- <https://nodesecurity.io/advisories/154>

Finding 57: GHSA-cqmj-92xf-r6r9 in socket.io-parser:4.0.5

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.20% / 42.32%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
socket.io-parser	4.0.5

File Path
/juice-shop/node_modules/socket.io-parser/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Insufficient validation when decoding a Socket.IO packet

Related Vulnerability Description: socket.io parser is a socket.io encoder and decoder written in JavaScript complying with version 5 of socket.io-protocol. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. A patch has been released in version 4.2.3.

Matcher: javascript-matcher

Package URL: pkg:npm/socket.io-parser@4.0.5

Mitigation

Upgrade to version: 4.2.3

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-cqmj-92xf-r6r9>

Vulnerability URLs:

- <https://github.com/socketio/socket.io-parser/security/advisories/GHSA-cqmj-92xf-r6r9>

- <https://github.com/socketio/socket.io-parser/commit/2dc3c92622dad113b8676be06f23bled46b02ced>
- <https://github.com/socketio/socket.io-parser/commit/3b78117bf6ba7e99d7a5cfc1ba54d0477554a7f3>
- <https://github.com/socketio/socket.io-parser/commit/1c220ddb45ea4b44bc8dbf6f9ae245f672ba1b9>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-32695>
- <https://github.com/socketio/socket.io-parser/releases/tag/4.2.3>
- <https://github.com/socketio/socket.io-parser/commit/ee006607495eca4ec7262ad080dd3a91439a5ba4>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2023-32695>

Related Vulnerability URLs:

- <https://github.com/socketio/socket.io-parser/commit/2dc3c92622dad113b8676be06f23bled46b02ced>
- <https://github.com/socketio/socket.io-parser/commit/3b78117bf6ba7e99d7a5cfc1ba54d0477554a7f3>
- <https://github.com/socketio/socket.io-parser/releases/tag/4.2.3>
- <https://github.com/socketio/socket.io-parser/security/advisories/GHSA-cqmj-92xf-r6r9>

Finding 58: GHSA-25hc-qcg6-38wj in socket.io:3.1.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.14% / 33.39%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
socket.io	3.1.2

File Path
/juice-shop/node_modules/socket.io/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: socket.io has an unhandled 'error' event

Related Vulnerability Description: Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. This issue is fixed by commit 15af22fc22 which has been included in socket.io@4.6.2 (released in May 2023). The fix was backported in the 2.x branch as well with commit d30630ba10. Users are advised to upgrade. Users unable to upgrade may attach a listener for the "error" event to catch these errors.

Matcher: javascript-matcher

Package URL: pkg:npm/socket.io@3.1.2

Mitigation

Upgrade to version: 4.6.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-25hc-qcg6-38wj>

Vulnerability URLs:

- <https://github.com/socketio/socket.io/security/advisories/GHSA-25hc-qcg6-38wj>
- <https://github.com/socketio/socket.io/commit/15af22fc22bc6030fcead322c106f07640336115>
- <https://github.com/socketio/socket.io/commit/d30630ba10562bf987f4d2b42440fc41a828119c>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-38355>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-38355>

Related Vulnerability URLs:

- <https://github.com/socketio/socket.io/commit/15af22fc22bc6030fcead322c106f07640336115>
- <https://github.com/socketio/socket.io/commit/d30630ba10562bf987f4d2b42440fc41a828119c>
- <https://github.com/socketio/socket.io/security/advisories/GHSA-25hc-qcg6-38wj>
- <https://www.vicarius.io/vsociety/posts/unhandled-exception-in-socketio-cve-2024-38355>

Finding 62: GHSA-952p-6rrq-rcjv in micromatch:3.1.10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.13% / 31.96%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
micromatch	3.1.10

File Path
/juice-shop/node_modules/micromatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Regular Expression Denial of Service (ReDoS) in micromatch

Related Vulnerability Description: The NPM package micromatch prior to 4.0.8 is vulnerable to Regular Expression Denial of Service (ReDoS). The vulnerability occurs in micromatch.braces() in index.js because the pattern .* will greedily match anything. By passing a malicious payload, the pattern matching will keep backtracking to the input while it doesn't find the closing bracket. As the input size increases, the consumption time will also increase until it causes the application to hang or slow down. There

was a merged fix but further testing shows the issue persists. This issue should be mitigated by using a safe pattern that won't start backtracking the regular expression due to greedy matching. This issue was fixed in version 4.0.8.

Matcher: javascript-matcher

Package URL: pkg:npm/micromatch@3.1.10

Mitigation

Upgrade to version: 4.0.8

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-952p-6rrq-rcjv>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2024-4067>
- <https://github.com/micromatch/micromatch/issues/243>
- <https://github.com/micromatch/micromatch/pull/247>
- <https://devhub.checkmarx.com/cve-details/CVE-2024-4067>
- <https://github.com/micromatch/micromatch/blob/2c56a8604b68c1099e7bc0f807ce0865a339747a/index.js#L448>
- <https://github.com/micromatch/micromatch/commit/500d5d6f42f0e8dfa1cb5464c6cb420b1b6aaaa0>
- <https://github.com/micromatch/micromatch/pull/266>
- <https://github.com/micromatch/micromatch/commit/03aa8052171e878897eee5d7bb2ae0ae83ec2ade>
- <https://advisory.checkmarx.net/advisory/CVE-2024-4067>
- <https://github.com/micromatch/micromatch/releases/tag/4.0.8>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-4067>

Related Vulnerability URLs:

- <https://advisory.checkmarx.net/advisory/CVE-2024-4067/>
- <https://devhub.checkmarx.com/cve-details/CVE-2024-4067/>
- <https://github.com/micromatch/micromatch/commit/03aa8052171e878897eee5d7bb2ae0ae83ec2ade>
- <https://github.com/micromatch/micromatch/pull/266>
- <https://github.com/micromatch/micromatch/releases/tag/4.0.8>
- <https://github.com/micromatch/micromatch/blob/2c56a8604b68c1099e7bc0f807ce0865a339747a/index.js#L448>
- <https://github.com/micromatch/micromatch/issues/243>
- <https://github.com/micromatch/micromatch/pull/247>

Finding 79: CVE-2026-22796 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.07% / 21.50%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: A type confusion vulnerability exists in the signature verification of signed PKCS#7 data where an ASN1_TYPE union member is accessed without first validating the type, causing an invalid or NULL pointer dereference when processing malformed PKCS#7 data. Impact summary: An application performing signature verification of PKCS#7 data or calling directly the PKCS7_digest_from_attributes() function can be caused to dereference an invalid or NULL pointer when reading, resulting in a Denial of Service. The function PKCS7_digest_from_attributes() accesses the message digest attribute value without validating its type. When the type is not V_ASN1_OCTET_STRING, this results in accessing invalid memory through the ASN1_TYPE union, causing a crash. Exploiting this vulnerability requires an attacker to provide a malformed signed PKCS#7 to an application that verifies it. The impact of the exploit is just a Denial of Service, the PKCS7 API is legacy and applications should be using the CMS API instead. For these reasons the issue was assessed as Low severity. The FIPS modules in 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS#7 parsing implementation is outside the OpenSSL FIPS module boundary. OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0, 1.1.1 and 1.0.2 are vulnerable to this issue.

Related Vulnerability Description: Issue summary: A type confusion vulnerability exists in the signature

verification of signed PKCS#7 data where an ASN1_TYPE union member is

accessed without first validating the type, causing an invalid or NULL

pointer dereference when processing malformed PKCS#7 data.

Impact summary: An application performing signature verification of PKCS#7

data or calling directly the PKCS7_digest_from_attributes() function can be

caused to dereference an invalid or NULL pointer when reading, resulting in

a Denial of Service.

The function PKCS7_digest_from_attributes() accesses the message digest attribute

value without validating its type. When the type is not V_ASN1_OCTET_STRING,

this results in accessing invalid memory through the ASN1_TYPE union, causing

a crash.

Exploiting this vulnerability requires an attacker to provide a malformed signed PKCS#7 to an application that verifies it. The impact of the exploit is just a Denial of Service, the PKCS7 API is legacy and applications should be using the CMS API instead. For these reasons the issue was assessed as Low severity.

The FIPS modules in 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS#7 parsing implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0, 1.1.1 and 1.0.2 are vulnerable to this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2026-22796>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-22796>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/2502e7b7d4c0cf4f972a881641fe09edc67aeec4>
- <https://github.com/openssl/openssl/commit/572844beca95068394c916626a6d3a490f831a49>
- <https://github.com/openssl/openssl/commit/7bbca05be55b129651d9df4bdb92becc45002c12>
- <https://github.com/openssl/openssl/commit/eeee3cbd4d682095ed431052f00403004596373e>
- <https://github.com/openssl/openssl/commit/ef2fb66ec571564d64d1c74a12e388a2a54d05d2>
- <https://openssl-library.org/news/secadv/20260127.txt>

Finding 92: GHSA-hjrf-2m68-5959 in jsonwebtoken:0.1.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.06% / 18.74%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.1.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsonwebtoken's insecure implementation of key retrieval function could lead to Forgeable Public/Private Tokens from RSA to HMAC

Related Vulnerability Description: jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Matcher: javascript-matcher

Package URL: pkg:npm/jsonwebtoken@0.1.0

Mitigation

Upgrade to version: 9.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-hjrf-2m68-5959>

Vulnerability URLs:

- <https://github.com/auth0/node-jwt-token/security/advisories/GHSA-hjrf-2m68-5959>
- <https://github.com/auth0/node-jwt-token/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>
- <https://github.com/auth0/node-jwt-token/releases/tag/v9.0.0>
- <https://security.netapp.com/advisory/ntap-20240621-0007>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jwt-token/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jwt-token/releases/tag/v9.0.0>

- <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>

Finding 93: GHSA-hjrf-2m68-5959 in jsonwebtoken:0.4.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.06% / 18.74%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.4.0

File Path
/juice-shop/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsonwebtoken's insecure implementation of key retrieval function could lead to Forgeable Public/Private Tokens from RSA to HMAC

Related Vulnerability Description: jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Matcher: javascript-matcher

Package URL: pkg:npm/jsonwebtoken@0.4.0

Mitigation

Upgrade to version: 9.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-hjrf-2m68-5959>

Vulnerability URLs:

- <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>
- <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

- <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>
- <https://security.netapp.com/advisory/ntap-20240621-0007>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>
- <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>

Finding 97: GHSA-qhxp-v273-g94h in sanitize-html:1.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.04% / 11.93%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
sanitize-html	1.4.2

File Path
/juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: sanitize-html is vulnerable to XSS through incomprehensive sanitization

Related Vulnerability Description: sanitize-html prior to version 2.0.0-beta is vulnerable to Cross-site Scripting (XSS). The sanitizeHtml() function in index.js does not sanitize content when using the custom transformTags option, which is intended to convert attribute values into text. As a result, malicious input can be transformed into executable code.

Matcher: javascript-matcher

Package URL: pkg:npm/sanitize-html@1.4.2

Mitigation

Upgrade to version: 2.0.0-beta

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-qhxp-v273-g94h>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2019-25225>
- <https://github.com/apostrophecms/sanitize-html/issues/293>
- <https://github.com/apostrophecms/sanitize-html/pull/156>
- <https://github.com/apostrophecms/sanitize-html/commit/712cb6895825c8bb6ede71a16b42bade42abcaf3>
- <https://github.com/Checkmarx/Vulnerabilities-Proofs-of-Concept/tree/main/2019/CVE-2019-25225>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2019-25225>

Related Vulnerability URLs:

- <https://github.com/Checkmarx/Vulnerabilities-Proofs-of-Concept/tree/main/2019/CVE-2019-25225>
- <https://github.com/apostrophecms/sanitize-html/commit/712cb6895825c8bb6ede71a16b42bade42abcaf3>
- <https://github.com/apostrophecms/sanitize-html/issues/293>
- <https://github.com/apostrophecms/sanitize-html/pull/156>

Finding 99: GHSA-9965-vmph-33xx in validator:13.15.15

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.04% / 10.50%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
validator	13.15.15

File Path
/juice-shop/node_modules/validator/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: validator.js has a URL validation bypass vulnerability in its isURL function

Related Vulnerability Description: A URL validation bypass vulnerability exists in validator.js through version 13.15.15. The isURL() function uses '://' as a delimiter to parse protocols, while browsers use '.' as the delimiter. This parsing difference allows attackers to bypass protocol and domain validation by crafting URLs leading to XSS and Open Redirect attacks.

Matcher: javascript-matcher

Package URL: pkg:npm/validator@13.15.15

Mitigation

Upgrade to version: 13.15.20

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-9965-vmph-33xx>

Vulnerability URLs:

- <https://nvd.nist.gov/vuln/detail/CVE-2025-56200>
- <https://gist.github.com/junan-98/27ae092aa40e2a057d41a0f95148f666>
- <https://gist.github.com/junan-98/a93130505b258b9e4ec9f393e7533596>
- <https://github.com/validatorjs/validator.js>
- <http://validatorjs.com>
- <https://github.com/validatorjs/validator.js/issues/2600>
- <https://github.com/validatorjs/validator.js/pull/2608>
- <https://github.com/validatorjs/validator.js/commit/cbef5088f02d36caf978f378bb845fe49bdc0809>
- <https://github.com/validatorjs/validator.js/releases/tag/13.15.20>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-56200>

Related Vulnerability URLs:

- <http://validatorjs.com>
- <https://gist.github.com/junan-98/27ae092aa40e2a057d41a0f95148f666>
- <https://gist.github.com/junan-98/a93130505b258b9e4ec9f393e7533596>
- <https://github.com/validatorjs/validator.js>

Finding 102: GHSA-r5mx-6wc6-7h9w in dottie:2.0.6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.03% / 9.57%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
dottie	2.0.6

File Path
/juice-shop/node_modules/dottie/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: dottie is vulnerable to Prototype Pollution bypass via non-first path segments in set() and transform()

Related Vulnerability Description: Dottie provides nested object access and manipulation in JavaScript. Versions 2.0.4 through 2.0.6 contain an incomplete fix for CVE-2023-26132. The prototype pollution guard introduced in commit 7d3aee1 only validates the first segment of a dot-separated path, allowing an attacker to bypass the protection by placing __proto__ at any position other than the first. Both dottie.set() and dottie.transform() are affected. Version 2.0.7 contains an updated fix to address the residual vulnerability.

Matcher: javascript-matcher

Package URL: pkg:npm/dottie@2.0.6

Mitigation

Upgrade to version: 2.0.7

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-r5mx-6wc6-7h9w>

Vulnerability URLs:

- <https://github.com/mickhansen/dottie.js/security/advisories/GHSA-r5mx-6wc6-7h9w>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27837>
- <https://github.com/mickhansen/dottie.js/commit/7e8fa1345a4b46325f0eab8d7aeb1c4deaefdb14>
- <https://github.com/advisories/GHSA-4gxf-g5gf-22h4>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-27837>

Related Vulnerability URLs:

- <https://github.com/advisories/GHSA-4gxf-g5gf-22h4>
- <https://github.com/mickhansen/dottie.js/commit/7e8fa1345a4b46325f0eab8d7aeb1c4deaefdb14>
- <https://github.com/mickhansen/dottie.js/security/advisories/GHSA-r5mx-6wc6-7h9w>

Finding 106: GHSA-xxjr-mmjv-4gpg in lodash:4.17.21

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.03% / 6.67%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
lodash	4.17.21

File Path
/juice-shop/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: Lodash has Prototype Pollution Vulnerability in `_.unset` and `_.omit` functions

Related Vulnerability Description: Lodash versions 4.0.0 through 4.17.22 are vulnerable to prototype pollution in the `_.unset` and `_.omit` functions. An attacker can pass crafted paths which cause Lodash to delete methods from global prototypes.

The issue permits deletion of properties but does not allow overwriting their original behavior.

This issue is patched on 4.17.23

Matcher: javascript-matcher

Package URL: pkg:npm/lodash@4.17.21

Mitigation

Upgrade to version: 4.17.23

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-xxjr-mmjv-4gpg>

Vulnerability URLs:

- <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-13465>
- <https://github.com/lodash/lodash/commit/edadd452146f7e4bad4ea684e955708931d84d81>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-13465>

Related Vulnerability URL: <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>

Finding 108: CVE-2025-9232 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.02% / 6.22%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: An application using the OpenSSL HTTP client API functions may trigger an out-of-bounds read if the 'no_proxy' environment variable is set and the host portion of the authority component of the HTTP URL is an IPv6 address. Impact summary: An out-of-bounds read can trigger a crash which leads to Denial of Service for an application. The OpenSSL HTTP client API functions can be used directly by applications but they are also used by the OCSP client functions and CMP (Certificate Management Protocol) client implementation in OpenSSL. However the URLs used by these implementations are unlikely to be controlled by an attacker. In this vulnerable code the out of bounds read can only trigger a crash. Furthermore the vulnerability requires an attacker-controlled URL to be passed from an application to the OpenSSL function and the user has to have a 'no_proxy' environment variable set. For the aforementioned reasons the issue was assessed as Low severity. The vulnerable code was introduced in the following patch releases: 3.0.16, 3.1.8, 3.2.4, 3.3.3, 3.4.0 and 3.5.0. The FIPS modules in 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this issue, as the HTTP client implementation is outside the OpenSSL FIPS module boundary.

Related Vulnerability Description: Issue summary: An application using the OpenSSL HTTP client API functions may

trigger an out-of-bounds read if the 'no_proxy' environment variable is set and

the host portion of the authority component of the HTTP URL is an IPv6 address.

Impact summary: An out-of-bounds read can trigger a crash which leads to

Denial of Service for an application.

The OpenSSL HTTP client API functions can be used directly by applications

but they are also used by the OCSP client functions and CMP (Certificate

Management Protocol) client implementation in OpenSSL. However the URLs used

by these implementations are unlikely to be controlled by an attacker.

In this vulnerable code the out of bounds read can only trigger a crash.

Furthermore the vulnerability requires an attacker-controlled URL to be

passed from an application to the OpenSSL function and the user has to have

a 'no_proxy' environment variable set. For the aforementioned reasons the

issue was assessed as Low severity.

The vulnerable code was introduced in the following patch releases:

3.0.16, 3.1.8, 3.2.4, 3.3.3, 3.4.0 and 3.5.0.

The FIPS modules in 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this

issue, as the HTTP client implementation is outside the OpenSSL FIPS module

boundary.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.17-1~deb12u3

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-9232>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-9232>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/2b4ec20e47959170422922eaff25346d362dcb35>
- <https://github.com/openssl/openssl/commit/654dc11d23468a74fc8ea4672b702dd3feb7be4b>
- <https://github.com/openssl/openssl/commit/7cf21a30513c9e43c4bc3836c237cf086e194af3>
- <https://github.com/openssl/openssl/commit/89e790ac431125a4849992858490bed6b225eadf>
- <https://github.com/openssl/openssl/commit/bbf38c034cdabd0a13330abcc4855c866f53d2e0>
- <https://openssl-library.org/news/secadv/20250930.txt>
- <http://www.openwall.com/lists/oss-security/2025/09/30/5>

Finding 111: GHSA-mh29-5h37-fv8m in js-yaml:3.14.1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.02% / 4.88%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
js-yaml	3.14.1

File Path
/juice-shop/node_modules/js-yaml/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: js-yaml has prototype pollution in merge (<<)

Related Vulnerability Description: js-yaml is a JavaScript YAML parser and dumper. In js-yaml before 4.1.1 and 3.14.2, it's possible for an attacker to modify the prototype of the result of a parsed yaml document via prototype pollution (__proto__). All users who parse untrusted yaml documents may be impacted. The problem is patched in js-yaml 4.1.1 and 3.14.2. Users can protect against this kind of attack on the server by using node --disable-proto=delete or deno (in Deno, pollution protection is on by default).

Matcher: javascript-matcher

Package URL: pkg:npm/js-yaml@3.14.1

Mitigation

Upgrade to version: 3.14.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-mh29-5h37-fv8m>

Vulnerability URLs:

- <https://github.com/nodeca/js-yaml/security/advisories/GHSA-mh29-5h37-fv8m>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-64718>
- <https://github.com/nodeca/js-yaml/commit/383665ff4248ec2192d1274e934462bb30426879>
- <https://github.com/nodeca/js-yaml/commit/5278870a17454fe8621dbd8c445c412529525266>
- <https://github.com/nodeca/js-yaml/issues/730#issuecomment-3549635876>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-64718>

Related Vulnerability URLs:

- <https://github.com/nodeca/js-yaml/commit/383665ff4248ec2192d1274e934462bb30426879>
- <https://github.com/nodeca/js-yaml/commit/5278870a17454fe8621dbd8c445c412529525266>
- <https://github.com/nodeca/js-yaml/issues/730#issuecomment-3549635876>
- <https://github.com/nodeca/js-yaml/security/advisories/GHSA-mh29-5h37-fv8m>

Finding 113: GHSA-qwph-4952-7xr6 in jsonwebtoken:0.1.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.02% / 3.91%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.1.0

File Path
/juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsonwebtoken vulnerable to signature validation bypass due to insecure default algorithm in jwt.verify()

Related Vulnerability Description: In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are

04.04.2026, 23:54

Finding Report

affected if you do not specify algorithms in the `jwt.verify()` function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the `none` algorithm in the `jwt.verify()` method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the `none` algorithm. If you need 'none' algorithm, you have to explicitly specify that in `jwt.verify()` options.

Matcher: javascript-matcher

Package URL: pkg:npm/jsonwebtoken@0.1.0

Mitigation

Upgrade to version: 9.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-qwph-4952-7xr6>

Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6>
- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>
- <https://security.netapp.com/advisory/ntap-20240621-0007>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>

Finding 114: GHSA-qwph-4952-7xr6 in jsonwebtoken:0.4.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.02% / 3.91%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
jsonwebtoken	0.4.0

File Path
/juice-shop/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsonwebtoken vulnerable to signature validation bypass due to insecure default algorithm in jwt.verify()

Related Vulnerability Description: In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Matcher: javascript-matcher

Package URL: pkg:npm/jsonwebtoken@0.4.0

Mitigation

Upgrade to version: 9.0.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-qwph-4952-7xr6>

Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6>
- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>
- <https://security.netapp.com/advisory/ntap-20240621-0007>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>

Related Vulnerability URLs:

- <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>

Finding 123: CVE-2026-22795 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.01% / 3.05%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: An invalid or NULL pointer dereference can happen in an application processing a malformed PKCS#12 file. Impact summary: An application processing a malformed PKCS#12 file can be caused to dereference an invalid or NULL pointer on memory read, resulting in a Denial of Service. A type confusion vulnerability exists in PKCS#12 parsing code where an ASN1_TYPE union member is accessed without first validating the type, causing an invalid pointer read. The location is constrained to a 1-byte address space, meaning any attempted pointer manipulation can only target addresses between 0x00 and 0xFF. This range corresponds to the zero page, which is unmapped on most modern operating systems and will reliably result in a crash, leading only to a Denial of Service. Exploiting this issue also requires a user or application to process a maliciously crafted PKCS#12 file. It is uncommon to accept untrusted PKCS#12 files in applications as they are usually used to store private keys which are trusted by definition. For these reasons, the issue was assessed as Low severity. The FIPS modules in 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS12 implementation is outside the OpenSSL FIPS module boundary. OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue. OpenSSL 1.0.2 is not affected by this issue.

Related Vulnerability Description: Issue summary: An invalid or NULL pointer dereference can happen in an application processing a malformed PKCS#12 file.

Impact summary: An application processing a malformed PKCS#12 file can be caused to dereference an invalid or NULL pointer on memory read, resulting in a Denial of Service.

A type confusion vulnerability exists in PKCS#12 parsing code where an ASN1_TYPE union member is accessed without first validating the type, causing an invalid pointer read.

The location is constrained to a 1-byte address space, meaning any attempted pointer manipulation can only target addresses between 0x00 and 0xFF.

This range corresponds to the zero page, which is unmapped on most modern operating systems and will reliably result in a crash, leading only to a Denial of Service. Exploiting this issue also requires a user or application to process a maliciously crafted PKCS#12 file. It is uncommon to accept untrusted PKCS#12 files in applications as they are usually used to store private keys which are trusted by definition. For these reasons, the issue was assessed as Low severity.

The FIPS modules in 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the PKCS12 implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue.

OpenSSL 1.0.2 is not affected by this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2026-22795>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-22795>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/2502e7b7d4c0cf4f972a881641fe09edc67aeec4>
- <https://github.com/openssl/openssl/commit/572844beca95068394c916626a6d3a490f831a49>
- <https://github.com/openssl/openssl/commit/7bbca05be55b129651d9df4bdb92becc45002c12>
- <https://github.com/openssl/openssl/commit/eeee3cbd4d682095ed431052f00403004596373e>
- <https://github.com/openssl/openssl/commit/ef2fb66ec571564d64d1c74a12e388a2a54d05d2>
- <https://openssl-library.org/news/secadv/20260127.txt>

Finding 124: CVE-2025-68160 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.01% / 2.50%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: Writing large, newline-free data into a BIO chain using the line-buffering filter where the next BIO performs short writes can trigger a heap-based out-of-bounds write. Impact summary: This out-of-bounds write can

cause memory corruption which typically results in a crash, leading to Denial of Service for an application. The line-buffering BIO filter (BIO_f_linebuffer) is not used by default in TLS/SSL data paths. In OpenSSL command-line applications, it is typically only pushed onto stdout/stderr on VMS systems. Third-party applications that explicitly use this filter with a BIO chain that can short-write and that write large, newline-free data influenced by an attacker would be affected. However, the circumstances where this could happen are unlikely to be under attacker control, and BIO_f_linebuffer is unlikely to be handling non-curated data controlled by an attacker. For that reason the issue was assessed as Low severity. The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue, as the BIO implementation is outside the OpenSSL FIPS module boundary. OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0, 1.1.1 and 1.0.2 are vulnerable to this issue.

Related Vulnerability Description: Issue summary: Writing large, newline-free data into a BIO chain using the

line-buffering filter where the next BIO performs short writes can trigger

a heap-based out-of-bounds write.

Impact summary: This out-of-bounds write can cause memory corruption which

typically results in a crash, leading to Denial of Service for an application.

The line-buffering BIO filter (BIO_f_linebuffer) is not used by default in

TLS/SSL data paths. In OpenSSL command-line applications, it is typically

only pushed onto stdout/stderr on VMS systems. Third-party applications that

explicitly use this filter with a BIO chain that can short-write and that

write large, newline-free data influenced by an attacker would be affected.

However, the circumstances where this could happen are unlikely to be under

attacker control, and BIO_f_linebuffer is unlikely to be handling non-curated

data controlled by an attacker. For that reason the issue was assessed as

Low severity.

The FIPS modules in 3.6, 3.5, 3.4, 3.3 and 3.0 are not affected by this issue,

as the BIO implementation is outside the OpenSSL FIPS module boundary.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0, 1.1.1 and 1.0.2 are vulnerable to this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-68160>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-68160>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/384011202af92605d926fafa4a0bcd6b65d162ad>
- <https://github.com/openssl/openssl/commit/475c466ef2fbd8fc1df6fae1c3eed9c813fc8ff6>
- <https://github.com/openssl/openssl/commit/4c96fbba618e1940f038012506ee9e21d32ee12c>
- <https://github.com/openssl/openssl/commit/6845c3b6460a98b1ec4e463baa2eala63a32d7c0>
- <https://github.com/openssl/openssl/commit/68a7cd2e2816c3a02f4d45a2ce43fc04fac97096>
- <https://openssl-library.org/news/secadv/20260127.txt>

Finding 135: CVE-2025-55132 in node:22.18.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.01% / 0.78%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
node	22.18.0

File Path
/nodejs/bin/node

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Vulnerability Namespace: nvd:cpe

Vulnerability Description: A flaw in Node.js's permission model allows a file's access and modification timestamps to be changed via futimes() even when the process has only read permissions. Unlike utimes(), futimes() does not apply the expected write-permission checks, which means file metadata can be modified in read-only directories. This behavior could be used to alter timestamps in ways that obscure activity, reducing the reliability of logs. This vulnerability affects users of the permission model on Node.js v20, v22, v24, and v25.

Matcher: stock-matcher

Package URL: pkg:generic/node@22.18.0

Mitigation

Upgrade to version:

- 20.20.0
- 22.22.0
- 24.13.0
- 25.3.0

References

Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-55132>

Vulnerability URL: <https://nodejs.org/en/blog/vulnerability/december-2025-security-releases>

Finding 136: CVE-2025-8058 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.01% / 0.50%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: The regcomp function in the GNU C library version from 2.4 to 2.41 is subject to a double free if some previous allocation fails. It can be accomplished either by a malloc failure or by using an interposed malloc that injects random malloc failures. The double free can allow buffer manipulation depending of how the regex is constructed. This issue affects all architectures and ABIs supported by the GNU C library.

Related Vulnerability Description: The regcomp function in the GNU C library version from 2.4 to 2.41 is

subject to a double free if some previous allocation fails. It can be accomplished either by a malloc failure or by using an interposed malloc that injects random malloc failures. The double free can allow buffer manipulation depending of how the regex is constructed. This issue affects all architectures and ABIs supported by the GNU C library.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

Mitigation

Upgrade to version: 2.36-9+deb12u13

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-8058>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-8058>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=33185

- <https://sourceware.org/git/?p=glibc.git;a=commit;h=3ff17af18c38727b88d9115e536c069e6b5d601f>

- <http://www.openwall.com/lists/oss-security/2025/07/23/1>

Finding 142: CVE-2025-69418 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Medium	0.01% / 0.21%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: Issue summary: When using the low-level OCB API directly with AES-NI or other hardware-accelerated code paths, inputs whose length is not a multiple of 16 bytes can leave the final partial block unencrypted and unauthenticated.

Impact summary: The trailing 1-15 bytes of a message may be exposed in cleartext on encryption and are not covered by the authentication tag, allowing an attacker to read or tamper with those bytes without detection.

The low-level OCB encrypt and decrypt routines in the hardware-accelerated stream path process full 16-byte blocks but do not advance the input/output pointers. The subsequent tail-handling code then operates on the original base pointers, effectively reprocessing the beginning of the buffer while leaving the actual trailing bytes unprocessed. The authentication checksum also excludes the true tail bytes.

However, typical OpenSSL consumers using EVP are not affected because the higher-level EVP and provider OCB implementations split inputs so that full blocks and trailing partial blocks are processed in separate calls, avoiding the problematic code path. Additionally, TLS does not use OCB ciphersuites. The vulnerability only affects applications that call the low-level CRYPTO_ocb128_encrypt() or CRYPTO_ocb128_decrypt() functions directly with non-block-aligned lengths in a single call on hardware-accelerated builds. For these reasons the issue was assessed as Low severity.

The FIPS modules in 3.6, 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this issue, as OCB mode is not a FIPS-approved algorithm.

OpenSSL 3.6, 3.5, 3.4, 3.3, 3.0 and 1.1.1 are vulnerable to this issue.

OpenSSL 1.0.2 is not affected by this issue.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

Mitigation

Upgrade to version: 3.0.18-1~deb12u2

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-69418>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-69418>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/commit/372fc5c77529695b05b4f5b5187691a57ef5dffc>
- <https://github.com/openssl/openssl/commit/4016975d4469cd6b94927c607f7c511385f928d8>
- <https://github.com/openssl/openssl/commit/52d23c86a54adab5ee9f80e48b242b52c4cc2347>
- <https://github.com/openssl/openssl/commit/a7589230356d908c0eca4b969ec4f62106f4f5ae>
- <https://github.com/openssl/openssl/commit/ed40856d7d4ba6cb42779b6770666a65f19cb977>
- <https://openssl-library.org/news/secadv/20260127.txt>

Low

Finding 128: GHSA-73rr-hh4g-fpgx in diff:4.0.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Low	0.02% / 4.80%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
diff	4.0.2

File Path
/juice-shop/node_modules/ts-node-dev/node_modules/diff/package.json

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: jsdiff has a Denial of Service vulnerability in parsePatch and applyPatch

Related Vulnerability Description: jsdiff is a JavaScript text differencing implementation. Prior to versions 8.0.3, 5.2.2, 4.0.4, and 3.5.1, attempting to parse a patch whose filename headers contain the line break characters \r, \u2028, or \u2029 can cause the parsePatch method to enter an infinite loop. It then consumes memory without limit until the process crashes due to running out of memory. Applications are therefore likely to be vulnerable to a denial-of-service attack if they call parsePatch with a user-provided patch as input. A large payload is not needed to trigger the vulnerability, so size limits on user input do not provide any protection. Furthermore, some applications may be vulnerable even when calling parsePatch on a patch generated by the application itself if the user is nonetheless able to control the filename headers (e.g. by directly providing the filenames of the files to be diffed). The applyPatch method is similarly affected if (and only if) called with a string representation of a patch as an argument, since under

the hood it parses that string using `parsePatch`. Other methods of the library are unaffected. Finally, a second and lesser interdependent bug - a ReDOS - also exhibits when those same line break characters are present in a patch's *patch* header (also known as its "leading garbage"). A maliciously-crafted patch header of length *n* can take `parsePatch` $O(n^3)$ time to parse. Versions 8.0.3, 5.2.2, 4.0.4, and 3.5.1 contain a fix. As a workaround, do not attempt to parse patches that contain any of these characters: `\r`, `\u2028`, or `\u2029`.

Matcher: javascript-matcher

Package URL: pkg:npm/diff@4.0.2

Mitigation

Upgrade to version: 4.0.4

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-73rr-hh4g-fpgx>

Vulnerability URLs:

- <https://github.com/kpdecker/jsdiff/security/advisories/GHSA-73rr-hh4g-fpgx>
- <https://github.com/kpdecker/jsdiff/pull/649>
- <https://github.com/kpdecker/jsdiff/commit/15a1585230748c8ae6f8274c202e0c87309142f5>
- <https://github.com/kpdecker/jsdiff/issues/653>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24001>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-24001>

Related Vulnerability URLs:

- <https://github.com/kpdecker/jsdiff/commit/15a1585230748c8ae6f8274c202e0c87309142f5>
- <https://github.com/kpdecker/jsdiff/issues/653>
- <https://github.com/kpdecker/jsdiff/pull/649>
- <https://github.com/kpdecker/jsdiff/security/advisories/GHSA-73rr-hh4g-fpgx>

Finding 1: DNS Rebinding Attack discovery dns network redirect

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Low	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'DNS Rebinding Attack' on 'localhost'	Active	March 6, 2026	April 4, 2026

Description

Detects DNS Rebinding attacks by checking if the DNS response contains a private IPv4 or IPv6 address.

Results:

127.0.0.1

Sample Request(s): Displaying 1 of 1

Request 1

```
;; opcode: QUERY, status: NOERROR, id: 41733
;; flags: rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096

;; QUESTION SECTION:
;localhost.      IN      A
```

Response 1

```
;; opcode: QUERY, status: NOERROR, id: 41733
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096
;; QUESTION SECTION:
;localhost.      IN      A
;; ANSWER SECTION:
localhost.      10800   IN      A      127.0.0.1
```

References

<https://capec.mitre.org/data/definitions/275.html>

<https://payatu.com/blog/dns-rebinding/>

<https://heimdalsecurity.com/blog/dns-rebinding/>

Finding 109: GHSA-w7fw-mjwx-w883 in qs:6.13.0

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Low	0.04% / 11.77%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
qs	6.13.0

File Path
/juice-shop/node_modules/qs/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: qs's arrayLimit bypass in comma parsing allows denial of service

Related Vulnerability Description: ### Summary

The arrayLimit option in qs does not enforce limits for comma-separated values when comma: true is enabled, allowing attackers to cause denial-of-service via memory exhaustion. This is a bypass of the array limit enforcement, similar to the bracket notation bypass addressed in GHSA-6rw7-vpxm-498p (CVE-2025-15284).

Details

When the comma option is set to true (not the default, but configurable in applications), qs allows parsing comma-separated strings as arrays (e.g., ?param=a,b,c becomes ['a', 'b', 'c']). However, the limit check for arrayLimit (default: 20) and the optional throwOnLimitExceeded occur after the comma-handling logic in parseArrayValue, enabling a bypass. This permits creation of arbitrarily large arrays from a single parameter, leading to excessive memory allocation.

Vulnerable code (lib/parse.js: lines ~40-50):

```
if (val && typeof val === 'string' && options.comma && val.indexOf(',') > -1) {
  return val.split(',');
}

if (options.throwOnLimitExceeded && currentArrayLength >= options.arrayLimit) {
  throw new RangeError('Array limit exceeded. Only ' + options.arrayLimit + ' element' + (options.arrayLimit === 1 ? '' : 's') + '
allowed in an array.');
```

```
return val;
```

The split(',') returns the array immediately, skipping the subsequent limit check. Downstream merging via utils.combine does not prevent allocation, even if it marks overflows for sparse arrays. This discrepancy allows attackers to send a single parameter with millions of commas (e.g., ?param=,,,,,,), allocating massive arrays in memory without triggering limits. It bypasses the intent of arrayLimit, which is enforced correctly for indexed (a[0]=) and bracket (a[]=) notations (the latter fixed in v6.14.1 per GHSA-6rw7-vpxm-498p).

PoC

Test 1 - Basic bypass:

```
npm install qs
```

```
const qs = require('qs');

const payload = 'a=' + ','.repeat(25); // 26 elements after split (bypasses arrayLimit: 5)
const options = { comma: true, arrayLimit: 5, throwOnLimitExceeded: true };

try {
  const result = qs.parse(payload, options);
  console.log(result.a.length); // Outputs: 26 (bypass successful)
} catch (e) {
  console.log('Limit enforced:', e.message); // Not thrown
}
```

Configuration:

- comma: true
- arrayLimit: 5
- throwOnLimitExceeded: true

Expected: Throws "Array limit exceeded" error.

Actual: Parses successfully, creating an array of length 26.

Impact

Denial of Service (DoS) via memory exhaustion.

Matcher: javascript-matcher

Package URL: pkg:npm/qs@6.13.0

Mitigation

Upgrade to version: 6.14.2

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-w7fw-mjwx-w883>

Vulnerability URLs:

- <https://github.com/ljharb/qs/security/advisories/GHSA-w7fw-mjwx-w883>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-2391>
- <https://github.com/ljharb/qs/commit/f6a7abff1f13d644db9b05fe4f2c98ada6bf8482>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2026-2391>

Related Vulnerability URLs:

- <https://github.com/ljharb/qs/commit/f6a7abff1f13d644db9b05fe4f2c98ada6bf8482>
- <https://github.com/ljharb/qs/security/advisories/GHSA-w7fw-mjwx-w883>

Finding 63: GHSA-pxg6-pf52-xh8x in cookie:0.4.2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Low	0.21% / 42.50%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
cookie	0.4.2

File Path
/juice-shop/node_modules/engine.io/node_modules/cookie/package.json

Description

Vulnerability Namespace: github:language:javascript

Vulnerability Description: cookie accepts cookie name, path, and domain with out of bounds characters

Related Vulnerability Description: cookie is a basic HTTP cookie parser and serializer for HTTP servers. The cookie name could be used to set other fields of the cookie, resulting in an unexpected cookie value. A similar escape can be used for path and domain, which could be abused to alter other fields of the cookie. Upgrade to 0.7.0, which updates the validation for name, path, and domain.

Matcher: javascript-matcher

Package URL: pkg:npm/cookie@0.4.2

Mitigation

Upgrade to version: 0.7.0

References

Vulnerability Datasource: <https://github.com/advisories/GHSA-pxg6-pf52-xh8x>

Vulnerability URLs:

- <https://github.com/jshttp/cookie/security/advisories/GHSA-pxg6-pf52-xh8x>
- <https://github.com/jshttp/cookie/pull/167>
- <https://github.com/jshttp/cookie/commit/e10042845354fea83bd8f34af72475eed1dadf5c>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2024-47764>

Related Vulnerability URLs:

- <https://github.com/jshttp/cookie/commit/e10042845354fea83bd8f34af72475eed1dadf5c>
- <https://github.com/jshttp/cookie/pull/167>
- <https://github.com/jshttp/cookie/security/advisories/GHSA-pxg6-pf52-xh8x>

Info

Finding 21: robots.txt File generic misc miscellaneous vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'robots.txt File' on 'http://localhost:3000/robots.txt'	Active	March 6, 2026	April 4, 2026

Description

None

Sample Request(s): Displaying 1 of 1

Request 1

GET /robots.txt HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.7.20) Gecko/ Firefox/3.6.7
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip

Response 1

HTTP/1.1 200 OK
Connection: close
Content-Length: 28
Access-Control-Allow-Origin: *
Content-Type: text/plain; charset=utf-8
Date: Fri, 06 Mar 2026 16:54:29 GMT
Etag: W/"lc-8HgF6mNyhsSFK0pascC9uB0wjX0"
Feature-Policy: payment 'self'
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
User-agent: *
Disallow: /ftp

Steps to Reproduce

curl command to reproduce the request:

curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.7.20) Gecko/ Firefox/3.6.7' 'http://localhost:3000/robots.txt'

Finding 139: CVE-2022-27943 in libgcc-s1:12.2.0-14+deb12u1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.05% / 15.32%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libgcc-s1	12.2.0-14+deb12u1

File Path
/var/lib/dpkg/status.d/libgcc-s1

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in demangle_const, as demonstrated by nm-new.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libgcc-s1@12.2.0-14%2Bdeb12u1?arch=arm64&distro=debian-12&upstream=gcc-12

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2022-27943>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-27943>

Related Vulnerability URLs:

- https://gcc.gnu.org/bugzilla/show_bug.cgi?id=105039
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/H424YXGW7OKXS2NCAP35OP6Y4P4AW6VG/>
- https://sourceware.org/bugzilla/show_bug.cgi?id=28995

Finding 140: CVE-2022-27943 in libgomp1:12.2.0-14+deb12u1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.05% / 15.32%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libgomp1	12.2.0-14+deb12u1

File Path
/var/lib/dpkg/status.d/libgomp1

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in demangle_const, as demonstrated by nm-new.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libgomp1@12.2.0-14%2Bdeb12u1?arch=arm64&distro=debian-12&upstream=gcc-12

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2022-27943>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-27943>

Related Vulnerability URLs:

- https://gcc.gnu.org/bugzilla/show_bug.cgi?id=105039
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/H424YXGW70KXS2NCAP35OP6Y4P4AW6VG/>
- https://sourceware.org/bugzilla/show_bug.cgi?id=28995

Finding 20: security.txt File generic misc miscellaneous vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'security.txt File' on 'http://localhost:3000/.well-known/security.txt'	Active	March 6, 2026	April 4, 2026

Description

File similar to robots.txt but intended to be read by humans wishing to contact a website's owner about security issues. Often defines a security policy and contact details.

Results:

mailto:donotreply@owasp-juice.shop

Sample Request(s): Displaying 1 of 1

Request 1

```
GET /.well-known/security.txt HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:59.0) Gecko/20100101 Firefox/59.0
Connection: close
Accept: */*
Accept-Language: en
```

Response 1

HTTP/1.1 200 OK
Connection: close
Content-Length: 475
Access-Control-Allow-Origin: *
Content-Type: text/plain; charset=utf-8
Date: Fri, 06 Mar 2026 16:54:20 GMT
Etag: W/"ldb-ZYYEygcemZ693+t2Y3qbrMHBivU"
Feature-Policy: payment 'self'
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
Contact: mailto:donotreply@owasp-juice.shop
Encryption: https://keybase.io/bkimminich/pgp_keys.asc?
fingerprint=19c01cb7157e4645e9e2c863062a85a8cbfbdcd
Acknowledgements: /#/score-board
Preferred-languages: en, ar, az, bg, bn, ca, cs, da, de, ga, el, es, et, fi, fr, ka, he, hi, hu, id, it, ja, ko, lv, my, nl, no, pl, pt, ro, ru, si, sv, th, tr, uk, zh
Hiring: /#/jobs
Csaf: http://localhost:3000/.well-known/csaf/provider-metadata.json
Expires: Sat...

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:59.0) Gecko/20100101 Firefox/59.0' 'http://localhost:3000/.well-known/security.txt'
```

References

- https://securitytxt.org/
- https://community.turgensec.com/security-txt-progress-in-ethical-security-research/

Finding 19: Missing Subresource Integrity compliance css js misconfig sri vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Missing Subresource Integrity' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

Checks if external script and stylesheet tags in the HTML response are missing the Subresource Integrity (SRI) attribute.

Results:

//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css

Request 1

Response 1

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; },
          &quot;button&quot;;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; }
        },
        &quot;...&quot;</script></head></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:106.0) Gecko/20100101 Firefox/106.0' 'http://localhost:3000/'
```

References

https://cheatsheetseries.owasp.org/cheatsheets/Third_Party_Javascript_Management_Cheat_Sheet.html#subresource-integrity

https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Finding 18: HTTP Missing Security Headers generic headers misconfig vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/ Firefox/3.6.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:54:06 GMT
Etag: W/"124fa-19cc3de7059";
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
```

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener('load', function(){
      window.cookieconsent.initialise({
        'palette': {
          'popup': { 'background': 'var(--theme-primary)',
'<div data-bbox="58 412 210 428" data-label="Section-Header">

### Steps to Reproduce



curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/
Firefox/3.6.15' 'http://localhost:3000'

Finding 17: HTTP Missing Security Headers generic headers misconfig vuln | Severity | EPSS Score / Percentile | Status | Date discovered | Age | Reporter | |--|-------------------------|-----------------|-----------------|---------|--------------------| | Info | N.A. / N.A. | Active | March 6, 2026 | 29 days | Admin User (admin) | | Endpoint | Status | Date Discovered | Last Modified | | | | 'HTTP Missing Security Headers' on 'http://localhost:3000' | Active | March 6, 2026 | April 4, 2026 | | |


```


```


Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Request 1

Response 1

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
```

```
&quot;text&quot;;: &quot;var(--theme-text)&quot; },
    &quot;button&quot;;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;,
&quot;text&quot;;: &quot;var(--theme-text)&quot; }
  },
  &quot;...</script></head></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/
Firefox/3.6.15' 'http://localhost:3000'
```

Finding 15: HTTP Missing Security Headers generic headers misconfig vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/ Firefox/3.6.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:54:06 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
```

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; },
          &quot;button&quot;;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; }
        },
        &quot;...&quot;</script></head></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/Firefox/3.6.15' 'http://localhost:3000'
```

Finding 14: HTTP Missing Security Headers generic headers misconfig vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/ Firefox/3.6.15
Connection: close
Accept: */*
Accept-Language: en
```


Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Request 1

Response 1

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
```

```
&quot;text&quot;;: &quot;var(--theme-text)&quot; },
    &quot;button&quot;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;,
&quot;text&quot;;: &quot;var(--theme-text)&quot; }
  },
  &quot;...&lt;/script>&lt;/head>&lt;/html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/
Firefox/3.6.15' 'http://localhost:3000'
```

Finding 141: CVE-2022-27943 in libstdc++6:12.2.0-14+deb12u1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.05% / 15.32%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libstdc++6	12.2.0-14+deb12u1

File Path
/var/lib/dpkg/status.d/libstdc++6

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in demangle_const, as demonstrated by nm-new.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libstdc%2B%2B6@12.2.0-14%2Bdeb12u1?arch=arm64&distro=debian-12&upstream=gcc-12

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2022-27943>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2022-27943>

Related Vulnerability URLs:

- https://gcc.gnu.org/bugzilla/show_bug.cgi?id=105039
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/H424YXGW7OKXS2NCAP35OP6Y4P4AW6VG/>
- https://sourceware.org/bugzilla/show_bug.cgi?id=28995

Finding 12: HTTP Missing Security Headers generic headers misconfig vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/ Firefox/3.6.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:54:06 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
```

```
<script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
<script>
  window.addEventListener('load', function() {
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)',
'<div data-bbox="58 216 210 231" data-label="Section-Header">

### Steps to Reproduce



curl command to reproduce the request:



curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/Firefox/3.6.15' 'http://localhost:3000'


```

Finding 126: CVE-2019-1010022 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.13% / 32.73%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9+deb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: https://security-tracker.debian.org/tracker/CVE-2019-1010022

Related Vulnerability Datasource: https://nvd.nist.gov/vuln/detail/CVE-2019-1010022

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=22850
- https://sourceware.org/bugzilla/show_bug.cgi?id=22850#c3
- <https://ubuntu.com/security/CVE-2019-1010022>

Finding 11: HTTP Missing Security Headers generic headers misconfig vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/ Firefox/3.6.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:54:06 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
```

```
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener('load', function(){
      window.cookieconsent.initialise({
        'palette': {
          'popup': { 'background': 'var(--theme-primary)',
'<script>...</script></head></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/
Firefox/3.6.15' 'http://localhost:3000'
```

Finding 10: HTTP Missing Security Headers generic headers misconfig vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Missing Security Headers' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.6.20) Gecko/ Firefox/3.6.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
```

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; },
          &quot;button&quot;;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; }
        },
        &quot;...&quot;</script></head></html>
```

curl command to reproduce the request:

Finding 8: OWASP Juice Shop discovery owasp tech

Vulnerable Endpoints / Systems (1)

Description

147/168

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/ Firefox/3.8
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:53:55 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
```

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; },
          &quot;button&quot;;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; }
        },
        &quot;...&quot;</script></head></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/
Firefox/3.8' 'http://localhost:3000'
```

Finding 7: Deprecated Feature-Policy Header - Detection deprecated feature-policy headers misc permissions

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Deprecated Feature-Policy Header - Detection' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

Detected the presence of the deprecated Feature-Policy HTTP response header. The Feature-Policy header has been deprecated and replaced by the Permissions-Policy header. While Feature-Policy is still supported in some browsers for backward compatibility, it is recommended to migrate to Permissions-Policy for future-proofing web applications.

Results:

payment 'self'

Sample Request(s): Displaying 1 of 1

Request 1

GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/ Firefox/3.8
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip

Response 1

HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:53:55 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment 'self'
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

<html lang="en" data-beasties-container>
<head>
 <meta charset="utf-8">
 <title>OWASP Juice Shop</title>

```
<meta name="description" content="Probably the most modern and sophisticated insecure web application">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
<link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
<script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
<script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
<script>
  window.addEventListener('load', function() {
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)',
'<div data-bbox="58 321 210 337" data-label="Section-Header">

### Steps to Reproduce



curl command to reproduce the request:

```
curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/
Firefox/3.8' 'http://localhost:3000'

References

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
- https://www.w3.org/TR/permissions-policy-1/
- https://github.com/w3c/webappsec-permissions-policy/blob/main/permissions-policy-explainer.md

Finding 6: Add DOM EventListener - Detection<div data-bbox="58 615 942 667" data-label="Table"> | Severity | EPSS Score / Percentile | Status | Date discovered | Age | Reporter | |----------|-------------------------|--------|-----------------|---------|--------------------| | Info | N.A. / N.A. | Active | March 6, 2026 | 29 days | Admin User (admin) | Vulnerable Endpoints / Systems (1) | Endpoint | Status | Date Discovered | Last Modified | |--|--------|-----------------|---------------| | 'Add DOM EventListener - Detection' on 'http://localhost:3000' | Active | March 6, 2026 | April 4, 2026 | Description Identifies the use of JavaScript addEventListener calls in the DOM.Sample Request(s): Displaying 1 of 1Request 1 ``` GET / HTTP/1.1 Host: localhost:3000 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/ Firefox/3.8 ``` localhost:8080/reports/quick?url=/engagement/1/finding/all 150/168


```


```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/
Firefox/3.8' 'http://localhost:3000'
```

References

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
- https://www.w3.org/TR/permissions-policy-1/
- https://github.com/w3c/webappsec-permissions-policy/blob/main/permissions-policy-explainer.md

Finding 6: Add DOM EventListener - Detection misc miscellaneous vuln xss

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Add DOM EventListener - Detection' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

Identifies the use of JavaScript addEventListener calls in the DOM.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/ Firefox/3.8
```

Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip

Response 1

HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:53:55 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment 'self'
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

```
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener(&quot;load&quot;;, function(){
      window.cookieconsent.initialise({
        &quot;palette&quot;;: {
          &quot;popup&quot;;: { &quot;background&quot;;: &quot;var(--theme-primary)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; },
          &quot;button&quot;;: { &quot;background&quot;;: &quot;var(--theme-accent)&quot;;,
&quot;text&quot;;: &quot;var(--theme-text)&quot;; }
        },
        &quot;...&quot;</script></head></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:1.9.7.20) Gecko/
Firefox/3.8' 'http://localhost:3000'
```

References

<https://portswigger.net/web-security/dom-based/controlling-the-web-message-source>

Finding 86: CVE-2019-1010024 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.65% / 70.35%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass ASLR using cache of thread stack and heap. The component is: glibc. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2019-1010024>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2019-1010024>

Related Vulnerability URLs:

- <http://www.securityfocus.com/bid/109162>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22852
- <https://support.f5.com/csp/article/K06046097>
- https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010024>

Finding 71: CVE-2019-1010025 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.86% / 74.66%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may guess the heap addresses of pthread_created thread. The component is: glibc. NOTE: the vendor's position is "ASLR bypass itself is not a vulnerability.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2019-1010025>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2019-1010025>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=22853
- <https://support.f5.com/csp/article/K06046097>
- https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010025>

Finding 70: CVE-2019-9192 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.86% / 74.70%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '() $\backslash$ 1' *in grep, a different issue than CVE-2018-20796. NOTE: the software maintainer disputes that this is a vulnerability because the behavior occurs only with a crafted pattern*

Matcher: dpkg-matcher

*Package URL:** pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2019-9192>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2019-9192>

Related Vulnerability URLs:

- https://sourceware.org/bugzilla/show_bug.cgi?id=24269
- https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS

Finding 5: robots.txt Endpoint Prober discovery generic misc miscellaneous

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'robots.txt Endpoint Prober' on 'http://localhost:3000/robots.txt'	Active	March 6, 2026	April 4, 2026

Description

Results:

/ftp

Sample Request(s): Displaying 1 of 1

Request 1

```
GET /robots.txt HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Content-Length: 28
Access-Control-Allow-Origin: *
Content-Type: text/plain; charset=utf-8
Date: Fri, 06 Mar 2026 16:53:51 GMT
Etag: W/"1c-8HgF6mNyhsSFK0pascC9uB0wjX0";
Feature-Policy: payment &#x27;self&#x27;
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
User-agent: *
Disallow: /ftp
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0' 'http://localhost:3000/robots.txt'
```

Finding 4: FingerprintHub Technology Fingerprint discovery tech

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'FingerprintHub Technology Fingerprint' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

FingerprintHub Technology Fingerprint tests run in nuclei.

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (Fedora; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
```

```
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:53:46 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
  <script>
    window.addEventListener('load', function() {
      window.cookieconsent.initialise({
        'palette': {
          'popup': { 'background': 'var(--theme-primary)',
'<div data-bbox="58 594 211 609" data-label="Section-Header">

### Steps to Reproduce



curl command to reproduce the request:



```
curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Fedora; Linux x86_64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36' 'http://localhost:3000'
```



### References



https://github.com/0x727/FingerprintHub



### Finding 59: CVE-2018-20796 in libc6:2.36-9+deb12u10



| Severity | EPSS Score / Percentile | Status | Date discovered | Age    | Reporter           |
|----------|-------------------------|--------|-----------------|--------|--------------------|
| Info     | 1.49% / 80.81%          | Active | April 4, 2026   | 0 days | Admin User (admin) |



localhost:8080/reports/quick?url=/engagement/1/finding/all



156/168


```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d " -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Fedora; Linux x86_64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36' 'http://localhost:3000'
```

References

<https://github.com/0x727/FingerprintHub>

Finding 59: CVE-2018-20796 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	1.49% / 80.81%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '(\227)(\1\1|t1|\2537)'+ in grep.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2018-20796>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2018-20796>

Related Vulnerability URLs:

- <http://www.securityfocus.com/bid/107160>
- <https://debbugs.gnu.org/cgi/bugreport.cgi?bug=34141>
- <https://lists.gnu.org/archive/html/bug-gnulib/2019-01/msg00108.html>
- <https://security.netapp.com/advisory/ntap-20190315-0002/>
- https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS

Finding 101: CVE-2010-4756 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.39% / 59.85%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: The glob implementation in the GNU C Library (aka glibc or libc6) allows remote authenticated users to cause a denial of service (CPU and memory consumption) via crafted glob expressions that do not match any pathnames, as demonstrated by glob expressions in STAT commands to an FTP daemon, a different vulnerability than CVE-2010-2632.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2010-4756>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2010-4756>

Related Vulnerability URLs:

- <http://cxib.net/stuff/glob-0day.c>
- http://securityreason.com/achievement_securityalert/89
- <http://securityreason.com/exploitalert/9223>
- https://bugzilla.redhat.com/show_bug.cgi?id=681681
- https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2010-4756
- <https://security.netapp.com/advisory/ntap-20241108-0002/>

Finding 3: Public Swagger API - Detect api discovery exposure swagger

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Public Swagger API - Detect' on 'http://localhost:3000/api-docs/swagger.json'	Active	March 6, 2026	April 4, 2026

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N

Description

Public Swagger API was detected.

Sample Request(s): Displaying 1 of 1

Request 1

GET /api-docs/swagger.json HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0

Accept: text/html, application/json
Accept-Language: en
Accept-Encoding: gzip

Response 1

HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Access-Control-Allow-Origin: *
Content-Type: text/html; charset=utf-8
Date: Fri, 06 Mar 2026 16:53:17 GMT
Etag: W/"c22-H8FH9nKD8DeX/nvIRrte6ZjP2a4"
Feature-Policy: payment 'self'
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

```
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Swagger UI</title>
  <link rel="stylesheet" type="text/css" href="./swagger-ui.css" >
  <link rel="icon" type="image/png" href="./favicon-32x32.png" sizes="32x32" /><link rel="icon"
type="image/png" href="./favicon-16x16.png" sizes="16x16" />
  <style>
    html
    {
      box-sizing: border-box;
      overflow: -moz-scrollbars-vertical;
      overflow-y: scroll;
    }
    *,
    *:before,
    *:after
    {
      box-sizing: inherit;
    }
    body {
      margin:0;
      background: #fafafa;
    }
  </style>
</head>
<body>
<svg xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xlink"
style="position:absolute;width:0;height:0">
  <defs>
    <symbol viewBox="0 0 20 20" id="unlocked">
      <path d="M15.8 8H14V5.6C14 2.703 12.665 1 10 1 7.334 1 6 2.703 6 5.6V6h2v-.801C8 3.754 8.797 3 10
3c1.203 0 2 .754 2 2.199V8H4c-.553 0-1 .646-1 1.199V17c0 .549.428 1.139.951 1.307l1.197.387C5.672
18.861 6.55 19 7.1 19h5.8c.549 0 1.428-.139 1.951-.307l1.196-.387c.524-.167.953-.757.953-1.306V9.199C17
8.646 16.352 8 15.8 8z"></path>
    </symbol>
    <symbol viewBox="0 0 20 20" id="locked">
      <path d="M15.8 8H14V5.6C14 2.703 12.665 1 10 1 7.334 1 6 2.703 6 5.6V8H4c-.553 0-1 .646-1
1.199V17c0 .549.428 1.139.951 1.307l1.197.387C5.672 18.861 6.55 19 7.1 19h5.8c.549 0 1.428-.139
1.951-.307l1.196-.387c.524-.167.953-.757.953-1.306V9.199C17 8.646 16.352 8 15.8 8zM12 8H8V5.6C8 2.703 6.665 1 4 1 1.334 1 0 2.703 0 5.6V6h2v-.801C2 3.754 2.797 3 4
3c1.203 0 2 .754 2 2.199V8H2c-.553 0-1 .646-1 1.199V17c0 .549.428 1.139.951 1.307l1.197.387C2.672
18.861 3.55 19 4.1 19h5.8c.549 0 1.428-.139 1.951-.307l1.196-.387c.524-.167.953-.757.953-1.306V9.199C17 8.646 16.352 8 15.8 8z"></path>
    </symbol>
```

```
8.797 3 10 3c1.203 0 2 .754 2 2.199V8z"/></path>
</symbol>
<symbol viewBox="0 0 20 20" id="close">
  <path d="M14.348 14.849c-.469.469-1.229.469-1.697 0L10 11.819l-2.651 3.029c-.469.469-1.229.469-
1.697 0-.469-.469-.469-1.229 0-1.697l2.758-3.15-2.759-3.152c-.469-.469-.469-1.228 0-1.697.469-.469
1.228-.469 1.697 0L10 8.183l2.651-3.031c.469-.469 1.228-.469 1.697 0 .469.469.469 1.229 0 1.697l-2.758
3.152 2.758 3.15c.469.469.469 1.229 0 1.698z"/></path>
</symbol>
<symbol viewBox="0 0 20 20" id="large-arrow">
  <path d="M13.25 10L6.109 2.58c-.268-.27-.268-.707 0-.979.268-.27.701-.27.969 0l7.83
7.908c.268.271.268.709 0 .979l-7.83 7.908c-.268.271-.701.27-.969 0-.268-.269-.268-.707 0-.979L13.25
10z"/></path>
</symbol>
<symbol viewBox="0 0 20 20" id="large-arrow-down">
  <path d="M17.418 6.109c.272-.268.709-.268.979 0s.271.701 0 .969l-7.908
7.83c-.27.268-.707.268-.979 0l-7.908-7.83c-.27-.268-.27-.701 0-.969.271-.268.709-.268.979 0L10
13.25l7.418-7.141z"/></path>
</symbol>
<symbol viewBox="0 0 24 24" id="jump-to">
  <path d="M19 7v4H5.83l3.58-3.59L8 6l-6 6 6 6 1.41-1.41L5.83 13H21V7z"/></path>
</symbol>
<symbol viewBox="0 0 24 24" id="expand">
  <path d="M10 18h4v-2h-4v2zM3 6v2h18V6H3zm3 7h12v-2H6v2z"/></path>
</symbol>
</defs>
</svg>
<div id="swagger-ui"></div>
<script src="./swagger-ui-bundle.js"> </script>
<script src="./swagger-ui-standalone-preset.js"> </script>
<script src="./swagger-ui-init.js"> </script>
<style>
  .swagger-ui .topbar ...</style></body></html>
```

Steps to Reproduce

curl command to reproduce the request:

```
curl -X 'GET' -d '' -H 'Accept: text/html, application/json' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0' 'http://localhost:3000/api-docs/swagger.json'
```

References

https://swagger.io/

Finding 25: CAA Record caa discovery dns

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'CAA Record' on 'localhost'	Active	March 6, 2026	April 4, 2026

Description

Sample Request(s): Displaying 1 of 1

Request 1

```
;; opcode: QUERY, status: NOERROR, id: 48028
;; flags: rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096

;; QUESTION SECTION:
;localhost.      IN      CAA
```

Response 1

```
;; opcode: QUERY, status: NOERROR, id: 48028
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096
;; QUESTION SECTION:
;localhost.      IN      CAA
;; AUTHORITY SECTION:
localhost.      10800   IN      SOA      localhost. nobody.invalid. 1 3600 1200 604800 10800
```

References

<https://support.dnssimple.com/articles/caa-record/#whats-a-caa-record>

Finding 24: NS Record Detection discovery dns ns

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'NS Record Detection' on 'localhost'	Active	March 6, 2026	April 4, 2026

Description

An NS record was detected. An NS record delegates a subdomain to a set of name servers.

Results:

localhost.

Sample Request(s): Displaying 1 of 1

Request 1

```
;; opcode: QUERY, status: NOERROR, id: 25718
;; flags: rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
```

```
; EDNS: version 0; flags:; udp: 4096

;; QUESTION SECTION:
;localhost.      IN      NS
```

Response 1

```
;; opcode: QUERY, status: NOERROR, id: 25718
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version 0; flags:; udp: 4096
;; QUESTION SECTION:
;localhost.      IN      NS
;; ANSWER SECTION:
localhost.      10800  IN      NS      localhost.
```

Finding 105: CVE-2019-1010023 in libc6:2.36-9+deb12u10

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.32% / 54.84%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libc6	2.36-9+deb12u10

File Path
/var/lib/dpkg/status.d/libc6

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: GNU Libc current is affected by: Re-mapping current loaded library with malicious ELF file. The impact is: In worst case attacker may evaluate privileges. The component is: libld. The attack vector is: Attacker sends 2 ELF files to victim and asks to run ldd on it. ldd execute code. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libc6@2.36-9%2Bdeb12u10?arch=arm64&distro=debian-12&upstream=glibc

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2019-1010023>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2019-1010023>

Related Vulnerability URLs:

- <http://www.securityfocus.com/bid/109167>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22851

- https://support.f5.com/csp/article/K11932200?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010023>

Finding 23: AAAA Record - IPv6 Detection aaaa discovery dns ipv6

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'AAAA Record - IPv6 Detection' on 'localhost'	Active	March 6, 2026	April 4, 2026

Description

An AAAA record was detected. AAAA records are used to map domain names to IPv6 addresses.

Results:

::1

Sample Request(s): Displaying 1 of 1

Request 1

```
;; opcode: QUERY, status: NOERROR, id: 8323
;; flags: rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096

;; QUESTION SECTION:
;localhost.      IN      AAAA
```

Response 1

```
;; opcode: QUERY, status: NOERROR, id: 8323
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096
;; QUESTION SECTION:
;localhost.      IN      AAAA
;; ANSWER SECTION:
localhost.      10800   IN      AAAA    ::1
```

References

<https://www.cloudflare.com/learning/dns/dns-records/dns-aaaa-record/>

https://en.wikipedia.org/wiki/IPv6_address

Finding 2: Wildcard DNS Configuration - Detection discovery dns wildcard

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)	200

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Wildcard DNS Configuration - Detection' on '3aaleil6kabpuvidnfvrbvizg4w-3aaleil6kabpuvidnfvrbvizg4w.localhost'	Active	March 6, 2026	April 4, 2026

Description

A wildcard DNS configuration was detected. Wildcard DNS records can resolve all subdomains to the same IP address, which may indicate a catch-all configuration.

Results:

127.0.0.1

Sample Request(s): Displaying 1 of 1

Request 1

```
;; opcode: QUERY, status: NOERROR, id: 40053
;; flags: rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096

;; QUESTION SECTION:
;3Aaleil6kaBpUviDNfvrBvIzg4W-3Aaleil6kaBpUviDNfvrBvIzg4W.localhost.      IN      A
```

Response 1

```
;; opcode: QUERY, status: NOERROR, id: 40053
;; flags: qr aa rd ra; QUERY: 1, ANSWER:1, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version 0; flags;; udp: 4096
;; QUESTION SECTION:
;3Aaleil6kaBpUviDNfvrBvIzg4W-3Aaleil6kaBpUviDNfvrBvIzg4W.localhost.      IN      A
;; ANSWER SECTION:
3Aaleil6kaBpUviDNfvrBvIzg4W-3Aaleil6kaBpUviDNfvrBvIzg4W.localhost.      10800   IN      A
127.0.0.1
```

References

- https://en.wikipedia.org/wiki/Wildcard_DNS_record
- <https://developers.cloudflare.com/dns/manage-dns-records/reference/wildcard-dns-records/>

Finding 137: CVE-2025-27587 in libssl3:3.0.17-1~deb12u2

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.05% / 15.74%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
libssl3	3.0.17-1~deb12u2

File Path
/var/lib/dpkg/status.d/libssl3

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: OpenSSL 3.0.0 through 3.3.2 on the PowerPC architecture is vulnerable to a Minerva attack, exploitable by measuring the time of signing of random messages using the EVP_DigestSign API, and then using the private key to extract the K value (nonce) from the signatures. Next, based on the bit size of the extracted nonce, one can compare the signing time of full-sized nonces to signatures that used smaller nonces, via statistical tests. There is a side-channel in the P-364 curve that allows private key extraction (also, there is a dependency between the bit size of K and the size of the side channel). NOTE: This CVE is disputed because the OpenSSL security policy explicitly notes that any side channels which require same physical system to be detected are outside of the threat model for the software. The timing signal is so small that it is infeasible to be detected without having the attacking process running on the same physical system.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/libssl3@3.0.17-1~deb12u2?arch=arm64&distro=debian-12&upstream=openssl

References

Vulnerability Datasource: <https://security-tracker.debian.org/tracker/CVE-2025-27587>

Related Vulnerability Datasource: <https://nvd.nist.gov/vuln/detail/CVE-2025-27587>

Related Vulnerability URLs:

- <https://github.com/openssl/openssl/issues/24253>
- <https://minerva.crocs.fi.muni.cz>

Finding 22: X-Recruiting Header employment generic hiring jobs misc miscellaneous vuln

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	N.A. / N.A.	Active	March 6, 2026	29 days	Admin User (admin)

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'X-Recruiting Header' on 'http://localhost:3000'	Active	March 6, 2026	April 4, 2026

Description

Websites that advertise jobs via HTTP headers

Results:

/#/jobs

Sample Request(s): Displaying 1 of 1

Request 1

```
GET / HTTP/1.1
Host: localhost:3000
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 14_4_1) AppleWebKit/605.1.15 (KHTML, like Gecko)
Version/17.3.1 Safari/605.1.15
Connection: close
Accept: */*
Accept-Language: en
Accept-Encoding: gzip
```

Response 1

```
HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Fri, 06 Mar 2026 16:54:33 GMT
Etag: W/"124fa-19cc3de7059"
Feature-Policy: payment &#x27;self&#x27;
Last-Modified: Fri, 06 Mar 2026 15:57:40 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticated insecure web
application">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
  <link rel="stylesheet" type="text/css"
href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
```

```
<script>
  window.addEventListener('load', function() {
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)',
'<div data-bbox="58 201 210 216" data-label="Section-Header">

### Steps to Reproduce



curl command to reproduce the request:


```

curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 14_4_1) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.3.1 Safari/605.1.15' 'http://localhost:3000'

References

https://webtechsurvey.com/response-header/x-recruiting

Finding 138: CVE-2022-27943 in gcc-12-base:12.2.0-14+deb12u1

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter
Info	0.05% / 15.32%	Active	April 4, 2026	0 days	Admin User (admin)

Location

Component	Version
gcc-12-base	12.2.0-14+deb12u1

File Path
/var/lib/dpkg/status.d/gcc-12-base

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

Vulnerability Namespace: debian:distro:debian:12

Vulnerability Description: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in demangle_const, as demonstrated by nm-new.

Matcher: dpkg-matcher

Package URL: pkg:deb/debian/gcc-12-base@12.2.0-14%2Bdeb12u1?arch=arm64&distro=debian-12&upstream=gcc-12

References

Vulnerability Datasource: https://security-tracker.debian.org/tracker/CVE-2022-27943

Related Vulnerability Datasource: https://nvd.nist.gov/vuln/detail/CVE-2022-27943

Related Vulnerability URLs:

- https://gcc.gnu.org/bugzilla/show_bug.cgi?id=105039
- <https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/H424YXGW7OKXS2NCAP35OP6Y4P4AW6VG/>
- https://sourceware.org/bugzilla/show_bug.cgi?id=28995